HW02 – Domain Testing on EShop

Course: Software Testing (FIT - VNUHCM University of Science)
Exercise ID: HW02-AI
Student Name: Phan Trung Tin
Student ID: 23120372
Submission Date: (to be filled)
Self-Assessed Grade: 095/100
SUT: EShop — https://github.com/ttbhanh/eshop-sut
Bloom-AI Level: G9.2 (Apply) · G9.3 (Analyse)

Table of Contents

- Feature Selection
- Feature A — FR-02: Login & Account Lockout (Pool A)
- Feature B — FR-09: Discount Coupons (Pool B)
- Feature C — FR-16: Product Import from CSV (Pool C)
- Feature D — FR-20: Mobile App (Pool D)
- Test Summary Report
- Assessment & Self-Assessment Rubric
- References

> Detailed AI Audit Report is in `AI_Audit_Report.md` (Appendix A).

> Bug details are in `Bug_Reports.md` + group's GitHub Issues page.

> This report was produced with the reusable skill `skills/domain-bva-tester/SKILL.md`.

---

1. Feature Selection

Slot	Pool	Selected FR	Rationale (many boundaries)
A	Pool A — Auth/Category/Product	**FR-02 Login & account lockout**	Count boundaries (2,3,4 fails) + time boundary (29/30/31s) + counter reset
B	Pool B — Cart/Checkout	**FR-09 Discount coupons (C1–C5)**	5 conjunctive conditions, `min_order-1/min_order/min_order+1`, `max_uses`, `expired_at`, percent/fixed
C	Pool C — Web Admin	**FR-16 Product import from CSV**	File boundaries (0/1/N rows), `price<=0`, missing column, RFC4180 quoted commas, atomic rollback
D	Pool D — Mobile App	**FR-20 Mobile (incl. cancel per FR-10 state machine)**	State boundaries `pending/confirmed/shipping`, form validation on mobile

Group non-duplication: confirmed with group members (to be listed in final version).

---

2. Feature A — FR-02: Login & Account Lockout (Pool A)

2.1 Spec summary (black-box, before code inspection)

- Inputs: Email (`type="email"`), Password.
- After each failed login, counter increments by exactly 1.
- >= 3 consecutive fails → lock 30s (demo env). Generic error message, no cause leak.

- Success returns JWT, sent as `Authorization: Bearer <token>`.
- Step indicator / back-to-login rules belong to FR-03, not FR-02.

2.2 Domain Testing (skill Step 1 — black-box, spec-only)

> Method: `skills/domain-bva-tester/SKILL.md` Step 1. Source: SRS v2.0 §FR-02 only.

> Backend/frontend login code was NOT inspected (preserved for Gap Analysis).

> Exact boundary values (fail #2/#3/#4, 29s/30s/31s) are deferred to §2.3 BVA.

2.2.1 Domain variables

#	Variable	Type	Spec constraint (FR-02)
V1	`email_format`	string	Must be valid email; field uses `type="email"` (HTML5)
V2	`email_registered`	boolean (DB state)	Account must exist; failure message must NOT leak cause
V3	`email_case`	string variant	Spec silent on case sensitivity
V4	`email_spaces`	string variant	Spec silent on leading/trailing whitespace
V5	`password_correct`	boolean	Must match stored credential; empty rejected
V6	`failed_attempts`	integer (account state)	+1 per failed login; `>=3` consecutive fails → lock 30s
V7	`lockout_elapsed`	time (account state)	Lock lasts 30s (demo); only meaningful when locked
V8	`account_status`	enum	`active` vs `locked` (no `disabled` state in spec)

2.2.2 Equivalence partitions

Variable	ID	Class	Partition description	Representative value
V1 email_format	VP1.1	Valid	Syntactically valid email	`test@eshop.com`
	IP1.1	Invalid	Missing `@`	`testeshop.com`
	IP1.2	Invalid	Missing domain part	`test@`
	IP1.3	Invalid	Empty string	`` (empty)
V2 email_registered	VP2.1	Valid	Email exists in DB	`test@eshop.com` (seed)
	IP2.1	Invalid	Well-formed but unregistered	`nouser999@eshop.com`
V3 email_case	VP3.1	Valid	Exact registered case	`test@eshop.com`
	SP3.1	Spec-silent	Different case	`TEST@ESHOP.COM`
V4 email_spaces	VP4.1	Valid	No surrounding spaces	`test@eshop.com`
	SP4.1	Spec-silent	Leading/trailing space	`␣test@eshop.com␣`
V5 password_correct	VP5.1	Valid	Correct password	`Test1234!`
	IP5.1	Invalid	Wrong password	`Wrong123!`
	IP5.2	Invalid	Empty password	`` (empty)
V6 failed_attempts	VP6.1	Valid	Fresh account, 0 prior fails	`0`
	VP6.2	Valid	Below threshold (1–2 fails)	`1`
	IP6.1	Invalid(=locked)	At/above threshold	`3` (just locked)
V7 lockout_elapsed	IP7.1	Invalid	Still inside lock window	retry immediately after lock
	VP7.1	Valid	Lock window expired	retry after 60s wait

V8 account_status	VP8.1	Valid	Active	normal account
	IP8.1	Invalid	Temporarily locked (30s)	account right after 3rd fail

`SP` = spec-silent partition (no expected behavior defined; actual recorded at execution, prime Gap-Analysis material).

2.2.3 Domain test cases

TC_ID	Partition / combination	Input data	Pre-conditions	Steps	Expected output	Actual Result	Status
TC-FR02-DOM-01	All-VP happy path	`test@eshop.com` / `Test1234!`	Fresh seed account, 0 fails, active	1. Open login 2. Enter creds 3. Submit	Login success, JWT returned (`Authorization: Bearer <token>`)	200 + JWT (D3-seed-happy-path)	PASSED
TC-FR02-DOM-02	IP1.1 bad format	`testeshop.com` / `Test1234!`	Active account	Submit login	Rejected (HTML5 `type=email` block or server 400); must not authenticate	401, not authenticated (C1). Note: UI uses `type=text`, so no HTML5 block — server rejects	PASSED
TC-FR02-DOM-03	IP1.3 + IP5.2 empty	` / `	Active account	Submit login	Rejected, required-field handling	401 at API (C2); UI blocks via `required`	PASSED
TC-FR02-DOM-04	IP2.1 unregistered	`nouser999@eshop.com` / `Any123!x`	Email not in DB	Submit login	Generic error only — indistinguishable from wrong-password message (no existence leak)	401 identical message (C0)	PASSED
TC-FR02-DOM-05	VP2.1 + IP5.1 first fail	`test@eshop.com` / `Wrong123!`	0 prior fails	Submit login	Generic error; `failed_attempts` = 1	401 but attempts = **2** (A1) → FR02-BUG-01	FAILED
TC-FR02-DOM-06	IP5.2 empty password	`test@eshop.com` / ``	0 prior fails	Submit login	Validation error (HTTP 400 / blocked at form); `failed_attempts` NOT incremented — if backend counts it as a fail toward lockout, log as defect (student decision 16/10)	401, attempts 2→**4** (C3) → FR02-BUG-03	FAILED
TC-FR02-DOM-07	VP6.2 below threshold	`test@eshop.com` / `Wrong123!`	1 prior consecutive fail	Submit login	Generic error; counter = 2; account still NOT locked	2nd fail → **locked**, attempts = 4 (A2) → FR02-BUG-01	FAILED
TC-FR02-DOM-08	IP6.1 threshold reached	`test@eshop.com` / `Wrong123!`	2 prior consecutive fails	Submit login (3rd fail)	Account locked for 30s; lockout message	Already locked since 2nd fail; 3rd submit → 403; duration **180s** not 30s → FR02-BUG-01/02	FAILED
TC-FR02-DOM-09	IP8.1 + IP7.1 locked, correct creds	`test@eshop.com` / `Test1234!`	Account just locked	Submit immediately	Still rejected — lock takes precedence over correct password	403 locked-message (A3)	PASSED
TC-FR02-DOM-10	VP7.1 lock expired	`test@eshop.com` / `Test1234!`	Locked, then wait 60s	Submit after wait	Login success (lock lifted)	Still 403 at 60s (180s lock); success only after ~180s/simulated expiry (A5, G4) → FR02-BUG-02	FAILED
TC-FR02-DOM-11	Counter reset on success ★ Gap-analysis focus	`test@eshop.com` / `Test1234!`	2 prior consecutive fails	Submit correct creds	Success AND consecutive-fail counter resets to 0 ("consecutive" per spec — student-confirmed 16/10)	200, attempts reset to 0, `locked_until` NULL (A5/H1)	PASSED

TC-FR02-DOM-12	Post-reset threshold ★ Gap-analysis focus	`test@eshop.com` / `Wrong123!` ×2	Right after DOM-11 success	Fail twice	Generic errors, counter = 2, NOT locked (proves reset)	2 fails after reset → **locked**, attempts = 4 (H2) → FR02-BUG-01	FAILED
TC-FR02-DOM-13	SP3.1 case variant	`TEST@ESHOP.COM` / `Test1234!`	Active account	Submit login	Student standard: expect case-insensitive accept; record actual at execution	401 (D1) → FR02-BUG-06	FAILED
TC-FR02-DOM-14	SP4.1 surrounding spaces	`␣test@eshop.com␣` / `Test1234!`	Active account	Submit login	Student standard: expect auto-trim accept; record actual at execution	401 (D2) → FR02-BUG-06	FAILED
TC-FR02-DOM-15	Message uniformity (O-domain)	wrong-pwd vs unregistered-email	Clean state	Run DOM-04 vs DOM-05, compare responses	Both responses identical in text + HTTP status (no cause leak)	401/401 identical (C0). Note: 403-locked class differs once locked	PASSED

Deferred to BVA (§2.3): fail-count edges 2/3/4, lockout timing 29s/30s/31s, counter-increment exactness (+1, no double-count on double-click), email max-length (spec-silent).

2.3 Boundary Value Analysis (skill Step 2 — black-box, spec-only)

> Method: `skills/domain-bva-tester/SKILL.md` Step 2. Thresholds from SRS: lock at `failed_attempts >= 3`, lock duration 30s.

> Login code still NOT inspected. Points already covered by DOM TCs are referenced, not duplicated.

2.3.1 Boundaries and step units

#	Boundary	Threshold	Step unit (u)	Operator under test
B1	Consecutive-fail count	T = 3	u = 1 attempt	`>= 3` vs `> 3` vs `>= 2` (off-by-one)
B2	Lockout elapsed time	T = 30s	u = 1s	`< 30` vs `<= 30` (expiry edge)
B3	Input string length	0 / 8*	u = 1 char	empty vs min+; hidden client pre-check? (*8 borrowed from FR-01 policy — FR-02 states none)
B4	Counter increment size	+1	u = 1	exactly +1 per fail (no double-count on double-submit)
B5/B6	Multi-variable	B1×correctness, B2×correctness	—	threshold × credential-correctness interaction

2.3.2 BVA point analysis

B1 — fail count (T=3, u=1):

Point	Value	Role	Rationale	Covered by
below	0–1	interior	No boundary significance	DOM-01/05
max-	2	just below threshold	Guards `>= 2` bug (would lock one fail early)	BVA-01
min (threshold)	3	transition	Decides `>= 3` vs `> 3` (latter locks only at 4)	BVA-02
max+	4	just above threshold	Lock persists; counter must not extend lock window	BVA-03

B2 — lockout elapsed (T=30s, u=1s):

Point	Value	Role	Rationale	Covered by
min	0s	just locked	Lock effective immediately	DOM-09
min+	1s	inside window	No early release	(implied; DOM-09)

nom	15s	mid-window sanity	Monotonic hold, guards timer bugs	BVA-08
max-	29s	just before expiry	Still locked; guards `< 29` / `<= 29` bug	BVA-05
edge	30s	expiry instant	Decides `< 30` vs `<= 30` — record actual	BVA-06
max+	31s	just after expiry	Lock definitely lifted	BVA-07

B3 — input length (u=1 char):

Point	Value	Role	Rationale	Covered by
min	0 chars	empty	Validation, no counter increment (per DOM-06 decision)	DOM-03/06
min+	1 char	shortest non-empty	Format/length rejection path	BVA-10
min- (vs 8)	7-char password	below FR-01 minimum	Probes hidden client pre-check; FR-02 expects server-processed generic error	BVA-11
max+	1000 chars	extreme length	Graceful rejection, no 500/hang/truncation login	BVA-12

B4 — increment exactness: double-submit of one wrong attempt must yield +1, not +2 (BVA-13).

Multi-variable: count=3 × correct password → success, no lock (BVA-04); time=30s × wrong password → fresh-window fail #1, not instant relock (BVA-09).

2.3.3 BVA test cases

TC_ID	Boundary / point	Input data	Pre-conditions	Steps	Expected output	Actual Result	Status
TC-FR02-BVA-01	B1 max- (2 fails)	`test@eshop.com` / `Wrong123!`	1 prior consecutive fail	Submit (2nd fail)	Generic error; counter = 2; NOT locked	2nd fail → **locked**, counter = 4 (A2) → FR02-BUG-01	FAILED
TC-FR02-BVA-02	B1 threshold (3rd fail)	`test@eshop.com` / `Wrong123!`	2 prior consecutive fails	Submit (3rd fail)	Locked 30s (proves `>= 3`, not `> 3`)	Locks — but already on 2nd fail and for 180s → FR02-BUG-01/02	FAILED
TC-FR02-BVA-03	B1 max+ (4th submit, locked)	`test@eshop.com` / `Test1234!`	Just locked	Submit twice more	Still rejected; lock window NOT extended (no sliding-window relock)	403 + DB unchanged (A4)	PASSED
TC-FR02-BVA-04	B1×correct (3rd try correct) ★	`test@eshop.com` / `Test1234!`	2 prior consecutive fails	Submit correct creds	Success, no lock (threshold counts fails only), counter reset	403 — locked since 2nd fail, correct-at-3rd impossible (F2) → FR02-BUG-01	FAILED
TC-FR02-BVA-05	B2 max- (29s)	correct creds	Locked 29s ago	Submit at 29s	Still rejected (locked)	403 at 29.0s (G2)	PASSED
TC-FR02-BVA-06	B2 edge (30s) ★	correct creds	Locked 30s ago	Submit at 30s	Operator determination: record accept/reject (`< 30` vs `<= 30`)	403 at 30.0s (G3) — masked by 180s duration; code isolates operator as `<` (server.js:40) → FR02-BUG-02	FAILED
TC-FR02-BVA-07	B2 max+ (31s)	correct creds	Locked 31s ago	Submit at 31s	Success (lock lifted)	403 at 31.1s (G4) → FR02-BUG-02	FAILED
TC-FR02-BVA-08	B2 nom (15s)	correct creds	Locked 15s ago	Submit at 15s	Still rejected (mid-window hold)	403 at 15.0s (G1)	PASSED
TC-FR02-BVA-09	B2×wrong (fail at 30s) ★	`test@eshop.com` / `Wrong123!`	Lock just expired (~30s)	Submit wrong creds	Generic error as fresh-window fail #1 (counter = 1), NOT instant relock	401 but attempts = **6** + relocked (B1) → FR02-BUG-04	FAILED
TC-FR02-BVA-10	B3 min+ (1 char)	`a` / `b`	Active account	Submit	Rejected (format/length); record counter behavior	401 in 2ms, graceful (E1)	PASSED

TC-FR02-BVA-11	B3 min- (7-char pwd)	`test@eshop.com` / `Abc123!` (7)	Active account	Submit	Generic wrong-password error (no length rule in FR-02); any client-side block recorded as extra-spec behavior	401 generic in 3ms (E2); no hidden pre-check at API	PASSED
TC-FR02-BVA-12	B3 max+ (1000 chars)	1000-char email / 1000-char password	Active account	Submit	Graceful rejection, no 500/timeout/partial login	401 in 12ms, no 500 (E3)	PASSED
TC-FR02-BVA-13	B4 increment exactness	`test@eshop.com` / `Wrong123!`	0 prior fails	Double-click submit rapidly for ONE attempt	Counter = 1 (exactly +1, no double-count)	0→**2** for two concurrent fails: unit is +2 **and** lost update (F1) → FR02-BUG-01/10	FAILED

FR-02 total: 15 DOM + 13 BVA + 9 GAP = **37 TCs**. Executed 16/10/2026 via `scripts/exec_fr02.js` (25 API steps, fresh users per scenario, ±1s tolerance on timing probes, ms-precision DB timestamps; lock expiry simulated via DB where noted).

2.4 AI Gap Analysis & Human Review

> White-box sources: `eshop-sut/backend/server.js:32-66` (login route), `backend/database.js:50-61,91-94` (users table + seeds), `frontend-web/src/pages/Login.jsx`, `frontend-web/src/context/AuthContext.jsx:26-35`.

2.4.1 How the code actually implements login/lockout

Spec question	Code answer	File:line
Counter storage	DB column `users.login_attempts` (+ `locked_until`); persists across restarts	database.js:56-57
Increment per fail	**+2, not +1** (`user.login_attempts + 2`)	server.js:54
Lock threshold	`newAttempts >= 3` — with +2 steps, lock fires on the **2nd** consecutive fail (0→2→4)	server.js:56
Lock duration	`Date.now() + 180000` = **180s (3 min), not 30s**	server.js:57
Expiry operator	`new Date() < new Date(locked_until)` → locked while `now < until`; exactly at `until` = unlocked (`<` semantics)	server.js:40
Reset on success	Yes: `login_attempts = 0, locked_until = NULL`	server.js:47-50
Reset on expiry	**None** — stale counter survives; first wrong attempt after expiry re-arms lock immediately (4+2=6)	server.js:54-62
Submit while locked	Early 403 return, DB untouched (no sliding-window extension)	server.js:40-44
Email normalization	**None** — exact `WHERE email = ?`, no `trim()` / `toLowerCase()` (SQLite BINARY match)	server.js:35
Empty password	Counted as a fail (**+2**) — no validation	server.js:46-54
Unknown vs wrong-pwd	Both 401 `"Invalid email or password"` — uniform, good	server.js:37-38,63
Locked response	Distinct 403 `"Tài khoản đã bị khóa..."` — reveals locked state	server.js:40-44
Login success body	Returns **full `user` row including plaintext `password`**; passwords stored plaintext (seed + register raw insert)	server.js:52, database.js:92-93, server.js:20-30
JWT	No `expiresIn`, hardcoded `SECRET_KEY` in source	server.js:9,51
Login form	Email `type="text"` (spec: `type="email"`); password `type="text"` (spec: `type="password"`, FR-22); heading `"Đăng Ký"` in `<h2>` (FR-21: one `<h1>`); label `Username`, button `Sign In` (FR-21: Vietnamese); error rendered **below** form (FR-22: above submit); submit has `tabIndex={1}` (FR-21 tab order); UI swallows 403 into generic `"Đăng nhập thất bại..."` so users never see lockout state	Login.jsx:24,28-46,53-59,61-66; AuthContext.jsx:27-33
Cross-FR note (for FR-03 phase)	Forgot-password OTP is **4-digit** (`1000+random*9000`) vs FR-03 spec 6-digit	server.js:72

2.4.2 What the 28 black-box TCs missed or assumed differently

#	Miss / clash	Root cause
M1	Assumed +1 increment (DOM-05/07, BVA-01/13) — code uses +2	**Dev bug** contradicting explicit spec ("đúng 1 đơn vị"); LLM assumed spec-faithful implementation
M2	Assumed 30s lock (DOM-08/10, BVA-05…09) — code uses 180s	**Dev bug** (wrong constant `180000`); black-box timing TCs all shift
M3	Assumed lock on 3rd fail (BVA-02) — code locks on 2nd	Derived from M1; **LLM never questioned the increment operator**
M4	Assumed expiry starts a fresh window (BVA-09) — stale counter re-arms lock instantly	**Dev bug** (no reset-on-expiry); LLM assumed symmetric state machine
M5	Never probed response-body shape — plaintext password leak missed	**LLM blind spot**: output-domain analysis stopped at status/message, ignored payload fields
M6	Never cross-checked GUI spec (FR-21/22) on the login form — `type=text`, wrong heading, error placement missed	**LLM blind spot**: treated FR-02 as API-only, skipped form-level requirements stated in the same spec
M7	Empty-password counting (DOM-06) — code counts +2, no validation	**Dev bug** (missing validation); student review decision already flagged the right expectation
M8	Correctly hedged via SP3.1/SP4.1 — code confirms no normalization	**Spec gap** (spec silent); black-box hedging was the right call, now confirmed as usability defect vs normalization standard

2.4.3 Supplementary white-box test cases

TC_ID	Discovery	Steps (high level)	Expected (spec/standard)	Actual Result	Status
TC-FR02-GAP-01	Early lock (M1+M3)	Fresh account → wrong pwd ×2	2nd fail must NOT lock (counter = 2)	2nd fail → locked, attempts = 4 (A2) → FR02-BUG-01	FAILED
TC-FR02-GAP-02	Duration (M2)	Lock account → read `locked_until − now` (ms)	≈ 30 000 ms, not ≈ 180 000 ms	**179 377 ms** ≈ 180s; 403 at 15/29/30/31s → FR02-BUG-02	FAILED
TC-FR02-GAP-03	Empty-pwd count (M7)	Fresh account → submit empty password via API	Validation error, counter unchanged	401, attempts 2→4 (C3) → FR02-BUG-03	FAILED
TC-FR02-GAP-04	Stale-counter relock (M4)	Lock → expire (or simulate) → 1 wrong attempt	Fresh-window fail #1 (counter = 1), no instant relock	401 but attempts = 6 + relocked (B1) → FR02-BUG-04	FAILED
TC-FR02-GAP-05	Password leak (M5)	Successful login → inspect response body	No `password` field in response; no plaintext storage (SEC-01)	Response carries plaintext `"Cx123456!"`; `/users/me` too; DB stores plaintext → FR02-BUG-05	FAILED
TC-FR02-GAP-06	Case sensitivity (M8)	`TEST@ESHOP.COM` + correct pwd	Accept (case-insensitive standard)	401 (D1) → FR02-BUG-06	FAILED
TC-FR02-GAP-07	Whitespace (M8)	`␣test@eshop.com␣` + correct pwd	Accept (auto-trim standard)	401 (D2) → FR02-BUG-06	FAILED
TC-FR02-GAP-08	Form input types (M6)	Inspect login form fields	Email `type="email"`, password `type="password"`	Both `type="text"` — password visible (Login.jsx:30,40; FR02_UI_LOGIN_PAGE.png) → FR02-BUG-07	FAILED
TC-FR02-GAP-09	Form feedback/i18n (M6)	Inspect headings, labels, error placement, tab order; trigger lockout in UI	Vietnamese `<h1>` title, error above submit, natural tab order, visible lockout state	Heading `"Đăng Ký"` in `<h2>`, `Username` / `Sign In` (EN), error below form, `tabIndex={1}`, 403 swallowed into generic message (Login.jsx:24,53-66) → FR02-BUG-08	FAILED

2.5 Execution & Bugs

> Executed 16/10/2026, 37/37 TCs. **13 PASSED, 24 FAILED → 10 bugs** (details: `Bug_Reports.md` §FR-02; screenshots: `screenshots/FR02_UI_LOGIN_PAGE.png`, `screenshots/FR02_API_EVIDENCE.png`; raw transcript: `scripts/exec_fr02_results.json`; runner: `scripts/exec_fr02.js`).

> Test accounts `exec*` left in DB (documented; seed accounts untouched except counter-resetting successful logins).

Bug ID	Title	Severity	Evidence	Related TCs
FR02-BUG-01	Fail counter increments by +2 → lockout fires on 2nd fail (spec: +1, lock on 3rd)	Critical	API evidence PNG (A1/A2/F2) + server.js:54	DOM-05/07/08/12, BVA-01/02/04/13, GAP-01
FR02-BUG-02	Lockout lasts ~180s instead of 30s	High	API evidence PNG (deltaMs 179377; G1–G4) + server.js:57	DOM-08/10, BVA-05…09, GAP-02
FR02-BUG-03	Empty password counted as failed attempt (+2)	High	API evidence PNG (C3) + server.js:46-54	DOM-06, GAP-03
FR02-BUG-04	Stale counter: first wrong attempt after expiry instantly re-arms lock (4→6)	High	API evidence PNG (B1) + server.js:54-62	BVA-09, GAP-04
FR02-BUG-05	Plaintext password in `POST /api/login` + `GET /api/users/me` responses; plaintext storage (SEC-01)	Critical (Security)	API evidence PNG (A5/A6) + server.js:52, database.js:92-93	GAP-05
FR02-BUG-06	No email normalization — uppercase / spaced emails rejected	Medium	API evidence PNG (D1/D2) + server.js:35	DOM-13/14, GAP-06/07
FR02-BUG-07	Login form: email + password inputs are `type="text"` (password visible on screen)	High	UI screenshot + Login.jsx:30,40	GAP-08
FR02-BUG-08	Login page: wrong `"Đăng Ký"` heading (`<h2>`), EN labels/buttons, error below form, `tabIndex={1}` , 403 lockout swallowed into generic message	Medium	UI screenshot + Login.jsx:24,53-66	GAP-09
FR02-BUG-09	JWT never expires (`no expiresIn`) + hardcoded `SECRET_KEY` in source	Medium (Security)	server.js:9,51	— (code inspection)
FR02-BUG-10	Lost update: two concurrent fails collapse 0→2 (read-modify-write + fire-and-forget `db.run`)	Medium	API evidence PNG (F1) + server.js:54-62	BVA-13

GitHub Issues: to be filed on the group repo with the PNGs attached (links added here after filing).

---

3. Feature B — FR-09: Discount Coupons (Pool B)

3.1 Spec summary

- 5 conditions must ALL hold: C1 code exists & `is_active=1` ; C2 `now < expired_at` ; C3 `total >= min_order_amount` ; C4 valid JWT; C5 `used_count < max_uses_per_user` .
- `percent: discount = total*value/100` ; `fixed: discount = value` ; `final = total - discount` .
- Sample codes: `SAVE10` (10%, min 300k, 2099-12-31, 1 use), `BIGBUY` (50k fixed, min 500k, 2099, 1), `VIP100` (100k fixed, min 300k, 2099, 2), `EXPIRED` (20%, min 100k, 2020-01-01, 1).

3.2 Domain Testing (skill Step 1 — black-box, spec-only)

> Method: `skills/domain-bva-tester/SKILL.md` Step 1. Sources: SRS v2.0 §FR-09 + the 4 seed codes only.

> Coupon/checkout code (backend + frontend) was NOT inspected (preserved for Gap Analysis).

> C-numbering below follows the SPEC (C1 exists+active · C2 `now < expired_at` · C3 `total >= min_order_amount` · C4 valid JWT · C5 `used < max_uses`).

> Reference prices: Keychron Q1 = 4 000 000 ₫ (qualifies all seeds); sub-threshold carts need an admin-created cheap item (setup note in TC).

> Exact money/date/count edges (`min−1/min/min+1` , expiry-day edges, 1st/2nd/3rd use) are deferred to §3.3 BVA.

3.2.1 Domain variables

#	Variable	Type	Spec constraint (FR-09)
V1	`coupon_code_text`	string	Free-text input at checkout
V2	`code_exists_active` (C1)	boolean (DB state)	Must exist AND `is_active = 1`
V3	`expired_at` (C2)	date (DB state)	`now` must be before `expired_at`
V4	`subtotal_vs_min` (C3)	money comparison	`total >= min_order_amount`
V5	`auth_jwt` (C4)	session state	Valid JWT required
V6	`used_vs_max` (C5)	count comparison	`used_count < max_uses_per_user`
V7	`discount_type`	enum	`percent`: `total×value/100`; `fixed`: `value`; `final = total − discount`
V8	`code_case` / `code_spaces`	string variants	Spec silent
V9	`stacking_repeat`	interaction	Spec silent: two codes / same code twice on one cart; rounding of percent math

3.2.2 Equivalence partitions

Variable	ID	Class	Partition description	Representative value
V1 text	VP1.1	Valid	Exact seed code	`SAVE10`
	IP1.1	Invalid	Well-formed but nonexistent	`FAKE99`
	IP1.2	Invalid	Empty string	`` (empty)
V2 C1	VP2.1	Valid	Exists + active	`SAVE10` (`is_active=1`)
	IP2.1	Invalid	Exists but deactivated (admin setup)	deactivated `SAVE10`
V3 C2	VP3.1	Valid	Unexpired	`SAVE10` (2099-12-31)
	IP3.1	Invalid	Expired	`EXPIRED` (2020-01-01)
V4 C3	VP4.1	Valid	Subtotal well above min	4 000 000 ₫ cart vs 300 000 ₫ min
	IP4.1	Invalid	Subtotal below min	50 000 ₫ test item vs 300 000 ₫ min
V5 C4	VP5.1	Valid	Logged in (JWT)	`test@eshop.com` session
	IP5.1	Invalid	Guest (no/invalid token)	logged-out checkout
V6 C5	VP6.1	Valid	Uses remaining	fresh user, or VIP100 1st/2nd use (max 2)
	IP6.1	Invalid	Quota exhausted	SAVE10 reused (max 1); VIP100 3rd use (max 2)
V7 type	VP7.1	Valid	Percent math	SAVE10 10% × 4 000 000 = 400 000 → final 3 600 000
	VP7.2	Valid	Fixed math	BIGBUY −50 000 → 3 950 000; VIP100 −100 000 → 3 900 000
V8 variants	SP8.1/8.2	Spec-silent	Lowercase / surrounding spaces	`save10`, `␣SAVE10␣` — record actual
V9 interaction	SP9.1–9.3	Spec-silent	Stack two codes / repeat same code / percent rounding (e.g. 10% × 4 555 555 = 455 555.5) — record actual	—

3.2.3 Domain test cases

TC_ID	Partition / combination	Input data	Pre-conditions	Steps	Expected output	Actual Result	Status
TC-FR09-DOM-01	All-VP percent happy path	Cart 4 000 000 ₫ + `SAVE10`, logged in, fresh user	C1–C5 all hold	Apply at checkout	−400 000 (10%), final 3 600 000	200 but discount **−36 000 000** → final **40 000 000** (H1) → FR09-BUG-01	FAILED

TC-FR09-DOM-02	All-VP fixed happy path	Cart 4 000 000 ₫ + `BIGBUY` (min 500k)	C1–C5 hold	Apply	−50 000, final 3 950 000	−50 000 → 3 950 000 (H2)	PASSED
TC-FR09-DOM-03	All-VP fixed happy path	Cart 4 000 000 ₫ + `VIP100` (min 300k)	C1–C5 hold	Apply	−100 000, final 3 900 000	−100 000 → 3 900 000 (H3)	PASSED
TC-FR09-DOM-04	C1 violated only	`FAKE99` on qualifying cart, logged in	C2–C5 hold, code nonexistent	Apply	Rejected (code does not exist)	404 uniform (V1)	PASSED
TC-FR09-DOM-05	C1 violated only (inactive)	Deactivated `SAVE10` (admin setup), qualifying cart	C2–C5 hold	Apply	Rejected (inactive)	404 via INACT1 fixture (V2)	PASSED
TC-FR09-DOM-06	C2 violated only	`EXPIRED` on ≥100 000 ₫ cart, logged in, fresh user	C1,C3–C5 hold	Apply	Rejected (expired)	400 expired (V3)	PASSED
TC-FR09-DOM-07	C3 violated only	`SAVE10` on 50 000 ₫ test item (admin-created), logged in	C1,C2,C4,C5 hold	Apply	Rejected (below 300 000 ₫ min)	400 min-gate (V4; total passed directly, no item needed)	PASSED
TC-FR09-DOM-08	C4 violated only	`SAVE10` on qualifying cart, logged out	C1–C3,C5 hold	Apply as guest	Rejected (login required)	**200 success quote** without any auth (V5) → FR09-BUG-03	FAILED
TC-FR09-DOM-09	C5 violated only	`SAVE10` reused by same user (max 1)	C1–C4 hold, quota spent	Use once → order again with `SAVE10`	2nd use rejected (quota exhausted)	400 after usage recorded (Q6)	PASSED
TC-FR09-DOM-10	C5 within quota	`VIP100` 1st + 2nd order (max 2)	C1–C4 hold	Two successive orders	Both succeed, −100 000 each	used 0→1→2 (Q1/Q2)	PASSED
TC-FR09-DOM-11	C5 violated only	`VIP100` 3rd order (max 2)	C1–C4 hold, quota spent	Third order	Rejected (quota exhausted)	400 quota message (Q3)	PASSED
TC-FR09-DOM-12	IP1.2 empty code	`` on qualifying cart, logged in	—	Apply empty	Rejected / validation message	400 validation (V6)	PASSED
TC-FR09-DOM-13	SP8.1 lowercase	`save10`, qualifying cart, logged in	C1–C5 hold for `SAVE10`	Apply	Record accept/reject as-is	404 via API (S1); UI normalizes trim+upper → would accept (layer divergence noted)	PASSED
TC-FR09-DOM-14	SP8.2 spaces	`␣SAVE10␣`, qualifying cart, logged in	C1–C5 hold	Apply	Record accept/reject/trim as-is	404 via API (S2); UI normalizes → would accept	PASSED
TC-FR09-DOM-15	SP9.1 stacking	`SAVE10` then `BIGBUY` on same cart	Both codes individually valid	Apply both	Student standard (16/10): max 1 code per order — new code must overwrite old or error; stacking discounts = serious business bug	Both **200** via API (K1) → FR09-BUG-08	FAILED

TC-FR09-DOM-16	SP9.2 repeat	`SAVE10` applied twice on same cart	Valid single use	Apply twice	Student standard (16/10): re-apply must be idempotent — NO double discount; double-charging discount = serious bug	Both **200** via API (K2) → FR09-BUG-08	FAILED
TC-FR09-DOM-17	SP9.3 rounding	10% on 4 555 555 ₫ total (admin-priced item)	C1–C5 hold	Apply `SAVE10`	Record exact discount (455 555.5 → ?): round up/down, final math	−40 999 995 → 45 555 550 (H4) — no rounding at all, formula bug → FR09-BUG-01	FAILED

FR-09 total so far: **17 TCs** (BVA edges to be added in §3.3).

3.3 Boundary Value Analysis (skill Step 2 — black-box, spec-only)

> Method: `skills/domain-bva-tester/SKILL.md` Step 2. **Threshold correction (verified 16/10 against SRS v2.0 + seed data):** `SAVE10` min = **300 000 ₫** (not 100 000), `VIP100` min = **300 000 ₫** (not 200 000), `BIGBUY` min = 500 000 ₫. All BVA points below use these verified values.

> Step units: money **u = 1 ₫** (DB/API integer precision — catches `<` vs `<=`); usage **u = 1 use**; time **u = 1 s**.

> Sub-threshold carts, near-term-expiry coupons and over-discount fixtures require admin/DB setup (student-approved 16/10, restore after run). Coupon/checkout code still NOT inspected.

3.3.1 Boundaries and step units

#	Boundary	Threshold	Step unit	Operator under test
B1	Subtotal vs `min_order` (C3)	per-code min	u = 1 ₫	`>=` vs `>` (off-by-one đồng)
B2	`used_count` vs `max_uses` (C5)	per-code max	u = 1 use	`<` vs `<=`; increment timing (apply vs checkout)
B3	`now` vs `expired_at` (C2)	per-coupon timestamp	u = 1 s	`<` vs `<=` at the exact second
B4	`final = subtotal − discount` floor	0 ₫	u = 1 ₫	floor at 0 vs negative total

3.3.2 BVA point analysis

B1 — C3 money edges (u = 1 ₫):

Code (min)	min− (reject)	min (accept)	min+ (accept)	Empty cart	TCs
SAVE10 (300 000)	299 999 → reject	300 000 → −30 000 → 270 000	300 001 → accept	0 → reject	BVA-01…04
BIGBUY (500 000)	499 999 → reject	500 000 → −50 000 → 450 000	500 001 → accept	(covered by SAVE10 empty)	BVA-05…07
VIP100 (300 000)	299 999 → reject	300 000 → −100 000 → 200 000	300 001 → accept	—	BVA-08…10

B2 — C5 usage edges (VIP100, max = 2, u = 1 use): used = 0 → 1st order pass (BVA-11); used = 1 → 2nd order pass at max (BVA-12); used = 2 → 3rd order reject max+ (BVA-13). Increment-timing probe: validate-only applies (no checkout) ×3 must NOT consume quota (BVA-14).

B3 — C2 time edges (fixture coupon expiring at T, u = 1 s): T−1s → accept max− (BVA-15); exactly T → probe `<` vs `<=`, record (BVA-16 ★); T+1s → reject max+ (BVA-17).

B4 — zero floor (fixture FIX200: fixed 200 000 ₫, min 0): subtotal 199 999 (discount−1) / 200 000 (=discount) / 200 001 (discount+1) → final must stop at 0, never negative (BVA-18…20).

3.3.3 BVA test cases

TC_ID	Boundary / point	Input data	Pre-conditions	Steps	Expected output	Actual Result	Status

TC-FR09-BVA-01	B1 empty cart	`SAVE10`, cart 0 ₫, logged in	C1,C2,C4,C5 hold	Apply	Rejected (below min)	400 min-gate (M0)	PASSED
TC-FR09-BVA-02	B1 SAVE10 min−	`SAVE10`, subtotal 299 999 ₫ (fixture item)	C1,C2,C4,C5 hold	Apply	Rejected — 1 ₫ short	400 (M1)	PASSED
TC-FR09-BVA-03	B1 SAVE10 min	`SAVE10`, subtotal 300 000 ₫	C1,C2,C4,C5 hold	Apply	Accept: −30 000 → final 270 000 (proves `>=`, not `>`)	**400** at exactly 300 000 (M2) → FR09-BUG-02	FAILED
TC-FR09-BVA-04	B1 SAVE10 min+	`SAVE10`, subtotal 300 001 ₫	C1,C2,C4,C5 hold	Apply	Accept	200 accept (M3; gate OK — money math covered by FR09-BUG-01)	PASSED
TC-FR09-BVA-05	B1 BIGBUY min−	`BIGBUY`, subtotal 499 999 ₫	C1,C2,C4,C5 hold	Apply	Rejected	400 (M4)	PASSED
TC-FR09-BVA-06	B1 BIGBUY min	`BIGBUY`, subtotal 500 000 ₫	C1,C2,C4,C5 hold	Apply	Accept: −50 000 → 450 000	**400** at exactly 500 000 (M5) → FR09-BUG-02	FAILED
TC-FR09-BVA-07	B1 BIGBUY min+	`BIGBUY`, subtotal 500 001 ₫	C1,C2,C4,C5 hold	Apply	Accept	200, −50 000 → 450 001 (M6)	PASSED
TC-FR09-BVA-08	B1 VIP100 min−	`VIP100`, subtotal 299 999 ₫	C1,C2,C4,C5 hold	Apply	Rejected	400 (M7)	PASSED
TC-FR09-BVA-09	B1 VIP100 min	`VIP100`, subtotal 300 000 ₫	C1,C2,C4,C5 hold	Apply	Accept: −100 000 → 200 000	**400** at exactly 300 000 (M8) → FR09-BUG-02	FAILED
TC-FR09-BVA-10	B1 VIP100 min+	`VIP100`, subtotal 300 001 ₫	C1,C2,C4,C5 hold	Apply	Accept	200, −100 000 → 200 001 (M9)	PASSED
TC-FR09-BVA-11	B2 used=0	`VIP100`, qualifying cart, fresh user	C1–C4 hold	1st order with code	Success, used → 1	used 0→1 (Q1)	PASSED
TC-FR09-BVA-12	B2 used=1 (at max)	`VIP100`, same user	C1–C4 hold, used = 1	2nd order	Success (at max, proves `< max+1` i.e. 2 allowed)	used 1→2 (Q2)	PASSED
TC-FR09-BVA-13	B2 max+ (used=2)	`VIP100`, same user	C1–C4 hold, used = 2	3rd order	Rejected (quota exhausted)	400 quota (Q3)	PASSED
TC-FR09-BVA-14	B2 increment timing ★	`VIP100`, qualifying cart	used = 0	Validate/apply on cart ×3 WITHOUT checkout, then place 1 order	Quota intact until checkout (used = 1 after order); apply-only must NOT consume uses	used 0→0 after 3 apply-only (N1) — holds trivially: nothing consumes on apply (see FR09-BUG-06)	PASSED
TC-FR09-BVA-15	B3 T−1s	Fixture coupon exp T, qualifying cart	C1,C3–C5 hold	Apply 1s before T	Accept (max−)	200 (E1)	PASSED
TC-FR09-BVA-16	B3 exactly T ★	Same fixture	C1,C3–C5 hold	Apply at second T	Probe: record accept/reject (`<` vs `<=`)	400 at T+17ms skew (E2) — post-expiry reject correct; exact-T operator per code `expiry < now` = accept	PASSED
TC-FR09-BVA-17	B3 T+1s	Same fixture	C1,C3–C5 hold	Apply 1s after T	Rejected (max+)	400 (E3)	PASSED
TC-FR09-BVA-18	B4 discount−1	Fixture FIX200 (fixed 200 000, min 0), subtotal 199 999 ₫	C1,C2,C4,C5 hold	Apply + checkout	Final = 0 (floor) — negative total = bug	Final **−1** (Z1) → FR09-BUG-07	FAILED

TC-FR09-BVA-19	B4 discount=subtotal	Same fixture, subtotal 200 000 ₫	C1,C2,C4,C5 hold	Apply + checkout	Final = 0 exactly	Final 0 (Z2)	PASSED
TC-FR09-BVA-20	B4 discount+1	Same fixture, subtotal 200 001 ₫	C1,C2,C4,C5 hold	Apply + checkout	Final = 1 ₫	Final 1 (Z3)	PASSED

FR-09 total: 17 DOM + 20 BVA + 11 GAP = **48 TCs**.

3.4 AI Gap Analysis & Human Review

> White-box sources: `eshop-sut/backend/server.js:297-309` (checkout), `:363-441` (apply-coupon), `:444-454` (coupon-usage), `:457-488` (admin coupon CRUD), `frontend-web/src/pages/Checkout.jsx`.

> Artifact 6 review decisions applied (16/10): spec-min banner kept; fixtures approved; BVA-14/16 probes kept.

3.4.1 How the code actually implements coupons

Spec question	Code answer	File:line
Check order C1→C5	C1 (exists+active, one query) → **C3 min** → C2 expiry → C5 usage (only if `user_id` supplied). C4 (JWT) **never checked** at apply	server.js:369-391
C3 operator	`total_amount > min_order_amount` — **strict `>`, spec says `>=`**; equality rejected	server.js:379
C2 operator	`expiry < now` → reject; exactly at `expired_at` = still valid (`<=` semantics)	server.js:380-384
C5 operator	`usage_count >= max` → reject (correct); but skipped entirely when `user_id` omitted	server.js:386-395
Percent math	`Math.floor(total × (1 − value))` — for SAVE10 (10): `4M × −9 = −36M` discount → final = **10× total**. Catastrophic	server.js:398-401,418-421
Fixed math	`discount = value`; **no floor** — fixed > subtotal → negative final	server.js:403,425
`used_count` increment	**Not** in apply, **not** in checkout — separate voluntary client call `POST /api/coupon-usage` *after* order creation; no transaction, no linkage	server.js:297-309,443-454; Checkout.jsx:53-59
Checkout validation	**None**: accepts any client `total_amount`, ignores `coupon_id`; no C1–C5 revalidation, no recompute (FR-08 violation)	server.js:297-309
Checkout total source	UI total is an **editable number input** (`editableTotal`); edits reset coupon state	Checkout.jsx:14,91-103
Code normalization	Backend exact match (no trim/lower); **UI** sends `trim().toUpperCase()` — layers diverge	server.js:370; Checkout.jsx:29
Single-code rule	Backend: none (unlimited applies per cart). UI: single `couponResult` slot (overwrite by design)	server.js:363-441; Checkout.jsx:18,98
Shipping in min_order	No shipping fee exists anywhere — SP moot	cart/checkout code
Cross-FR notes (later phases)	No role check on admin coupon CRUD (any login creates coupons — FR-12); user-cancel allowed from `shipping` (FR-10, comment admits it); `GET /api/orders/:id` unauthenticated (FR-11); `canceled → delivered` accepted (FR-10)	server.js:321-342,344-349,457-488,525-551

3.4.2 What the 37 black-box TCs missed or assumed differently

#	Miss / clash	Root cause
M1	Assumed `>=` for min (BVA-03/06/09) — code uses `>`	**Dev bug** (wrong operator); LLM assumed spec-faithful operator
M2	Assumed spec percent formula — code computes `total×(1−value)` (negative discount, 10× final)	**Dev bug** (catastrophic); LLM probed thresholds, never the formula implementation
M3	Assumed C4 enforced at apply (DOM-08) — endpoint has no auth, `user_id` is client-supplied	**Dev bug** (missing auth); LLM assumed endpoint wiring matches spec

M4	Assumed quota enforced atomically at checkout (BVA-11…14) — usage is a voluntary post-checkout client call	**Dev/architecture bug**; LLM assumed transactional integrity
M5	Assumed checkout revalidates + recomputes (FR-08) — trusts any client total, ignores coupon	**Dev bug** (missing trust boundary); LLM didn't probe client→server trust
M6	Assumed raw code pass-through (SP8) — UI normalizes trim+upper, backend doesn't	**Layer divergence**; SP hedging was right but layer-specific expectations needed
M7	Assumed C5 always evaluated — skipped when `user_id` omitted (`if (user_id)`)	**Dev bug**; LLM assumed unconditional evaluation
M8	Assumed floor-at-0/reject for over-discount (B4) — no floor, negatives possible	**Dev bug**; BVA-18…20 probes correctly placed

3.4.3 Supplementary white-box test cases

TC_ID	Discovery	Steps (high level)	Expected (spec/standard)	Actual Result	Status
TC-FR09-GAP-01	Equality `>` bug (M1)	SAVE10 on exactly 300 000 ₫	Accept, −30 000 (proves `>=`)	400 at equality (M2) → FR09-BUG-02	FAILED
TC-FR09-GAP-02	Percent math (M2)	SAVE10 on 4 000 000 ₫, inspect math	Discount 400 000, final 3 600 000	−36 000 000 → 40 000 000 (H1) → FR09-BUG-01	FAILED
TC-FR09-GAP-03	Guest apply (M3)	No token, no `user_id` , valid code + total	Rejected (C4 login required)	200 quote; 200 with foreign id (V5/V7) → FR09-BUG-03	FAILED
TC-FR09-GAP-04	Omitted `user_id` (M7)	Exhausted user, apply WITHOUT `user_id`	Still rejected (C5 must hold regardless)	200 (Q7) → FR09-BUG-04	FAILED
TC-FR09-GAP-05	Foreign `user_id` (M3)	Exhausted user, apply with ANOTHER fresh user's id	Rejected (quota is per-caller, server-known)	200 (Q8) → FR09-BUG-03	FAILED
TC-FR09-GAP-06	Tampered total via API (M5)	Auth'd `POST /api/checkout` with `total_amount = 1`	Rejected/recomputed — never a 1 ₫ order	Order #4 stored `total_amount = 1` (T1) → FR09-BUG-05	FAILED
TC-FR09-GAP-07	Usage never recorded (M4)	Checkout with SAVE10, skip `/api/coupon-usage` , reuse SAVE10	2nd use rejected (server-side quota)	Reuse 200, used = 0 (Q4) → FR09-BUG-06	FAILED
TC-FR09-GAP-08	Double usage record (M4)	One order → call `/api/coupon-usage` twice	2nd record rejected (idempotent, 1 use per order)	used = 2 for one order (Q5) → FR09-BUG-06	FAILED
TC-FR09-GAP-09	UI editable total (M5)	Set checkout total input to 1 ₫ → checkout	Total not user-editable; server recomputes	Editable input exists; server accepts any total (screenshot + T1) → FR09-BUG-09/05	FAILED
TC-FR09-GAP-10	Last-quota race (M4)	VIP100 at used = 1 → two PARALLEL applies	At most one succeeds (atomic check-and-reserve)	Both 200 (R1) → FR09-BUG-10	FAILED
TC-FR09-GAP-11	API stacking (single-code std)	SAVE10 then BIGBUY via API, same cart	2nd apply overwrites or errors (max 1 code/order)	Both 200 (K1) → FR09-BUG-08	FAILED

3.5 Execution & Bugs

> Executed 16/10/2026, 48/48 TCs. **28 PASSED, 20 FAILED → 10 bugs** (details: `Bug_Reports.md` §FR-09; screenshots: `screenshots/FR09_UI_CHECKOUT.png` , `screenshots/FR09_API_EVIDENCE.png` ; raw transcript: `scripts/exec_fr09_results.json` ; runner: `scripts/exec_fr09.js`).

> Fixtures TIMEB1/FIX200/INACT1 created via admin endpoint and deleted afterwards (seeds = 4 verified). Test accounts `cpn*` + usage rows left in DB (documented).

Bug ID	Title	Severity	Evidence	Related TCs
FR09-BUG-01	Percent formula `total×(1−value)` → negative discount, final = 10× total	Critical	API evidence PNG (H1/H4) + server.js:398-421	DOM-01/17, GAP-02
FR09-BUG-02	C3 strict `>` rejects subtotal == min (spec `>=`)	High	API evidence PNG (M2/M5/M8) + server.js:379	BVA-03/06/09, GAP-01

FR09-BUG-03	`POST /api/apply-coupon` has no auth; `user_id` client-supplied (quota impersonation)	High	API evidence PNG (V5/V7/Q8) + server.js:363-391	DOM-08, GAP-03/05
FR09-BUG-04	Usage check skipped when `user_id` omitted (`if (user_id)`)	High	API evidence PNG (Q7) + server.js:386	GAP-04
FR09-BUG-05	Checkout trusts any client `total_amount` , ignores coupon (1 ₫ order stored)	Critical	API evidence PNG (T1, order #4) + server.js:297-309	GAP-06
FR09-BUG-06	Quota = voluntary post-checkout client call: unlimited reuse, double-count, no linkage	High	API evidence PNG (Q4/Q5/N1) + server.js:443-454	BVA-14, GAP-07/08
FR09-BUG-07	No zero floor: fixed > subtotal → negative `final_amount` (−1 ₫)	High	API evidence PNG (Z1) + server.js:406	BVA-18
FR09-BUG-08	No server-side single-code rule: stacking + repeat apply via API	Medium	API evidence PNG (K1/K2) + server.js:363-441	DOM-15/16, GAP-11
FR09-BUG-09	Checkout total is an editable input (FR-08 UI violation)	High	UI screenshot + Checkout.jsx:14,91-103	GAP-09
FR09-BUG-10	Last-quota race: parallel applies both pass (no transaction)	Medium	API evidence PNG (R1) + server.js:386-395	GAP-10

GitHub Issues: to be filed on the group repo with the PNGs attached (links added here after filing).

---

4. Feature C — FR-16: Product Import from CSV (Pool C)

4.1 Spec summary

- File must end `.csv` ; header `name,price,description,imageUrl,category_id` ; RFC4180 quoted commas.
- Pre-validation: `name` non-empty; `price` positive number.
- Any row error → full rollback (all-or-nothing); clear success/error count report.

4.2 Domain Testing (skill Step 1 — black-box, spec-only)

> Method: `skills/domain-bva-tester/SKILL.md` Step 1. Sources: SRS v2.0 §FR-16 + FR-12 (admin-only data APIs) + FR-15 (product field rules).

> Import code (backend + frontend-admin) was NOT inspected (preserved for Gap Analysis).

> **Header caveat (verified against SRS):** spec header is `name,price,description,imageUrl,category_id` — **no `stock` column**. `stock` below is kept per brief as **SP (verify at white-box/execution whether the real template accepts it)**.

> Exact count/size edges (0/1/N rows, price 0/0.01/−1, max file size) are deferred to §4.3 BVA.

4.2.1 Domain variables (3 layers)

Layer	#	Variable	Type	Spec constraint (FR-16 / FR-12)
File/Request	V1	`auth_role`	enum	Admin-only (`role='admin'` + valid JWT); customer → forbidden; guest → 401
	V2	`file_presence_format`	file	`.csv` required; missing file / `.txt` / `.json` / `.xlsx` /binary → rejected
	V3	`encoding`	bytes	Must handle UTF-8 Vietnamese diacritics (Áo thun, Bàn phím...)
CSV structure	V4	`header_row`	string	First line exactly `name,price,description,imageUrl,category_id`
	V5	`column_count`	int	Data rows must match header arity (5 fields)
	V6	`rfc4180_quoting`	string	Comma/quote fields wrapped in `"..."` must parse as one field
Row data	V7	`name`	string	Non-empty (whitespace-only = empty)

	V8	`price`	number	Positive number (`> 0`); `0` /negative/non-numeric rejected
	V9	`category_id`	FK int	Must reference an existing category
	V10	`stock`	SP int	**Spec-silent** — verify real template; if accepted: integer `>= 0`
Batch	V11	`batch_composition`	state	All-valid → commit N; ANY row invalid → rollback ALL (atomic, count unchanged) + per-row error report

4.2.2 Equivalence partitions

Variable	ID	Class	Partition description	Representative value
V1 role	VP1.1	Valid	Admin JWT	`admin@eshop.com` session
	IP1.1	Invalid	Customer JWT	`test@eshop.com` session
	IP1.2	Invalid	No token	guest request
V2 file	VP2.1	Valid	`.csv` attached	`products.csv`
	IP2.1	Invalid	No file	empty multipart body
	IP2.2	Invalid	Wrong extension/type	`products.txt` (CSV content), `.xlsx` binary
V3 encoding	VP3.1	Valid	UTF-8 Vietnamese	`Áo thun cotton,100000,…`
V4 header	VP4.1	Valid	Exact header	`name,price,description,imageUrl,category_id`
	IP4.1	Invalid	Wrong/missing column names	`title,price,desc,img,cat`
V5 arity	VP5.1	Valid	5 fields per row	`Áo,100000,mô tả,http://x/y.png,1`
	IP5.1	Invalid	4 fields (missing)	`Áo,100000,mô tả,http://x/y.png`
	IP5.2	Invalid	6 fields (extra)	`…,1,EXTRA`
V6 quoting	VP6.1	Valid	RFC4180 quoted comma	`"Áo, thun",100000,…` → one field
	VP6.2	Valid	RFC4180 escaped quote	`"Áo ""đẹp""",100000,…` → one field
V7 name	VP7.1	Valid	Non-empty	`Bàn phím cơ`
	IP7.1	Invalid	Empty / whitespace-only	`` ` ` / ␣ ` ``
V8 price	VP8.1	Valid	Positive	`100000`
	IP8.1	Invalid	Zero	`0`
	IP8.2	Invalid	Negative	`-5000`
	IP8.3	Invalid	Non-numeric	`abc`
V9 category	VP9.1	Valid	Existing id	`1` (seeded)
	IP9.1	Invalid	Nonexistent id	`9999`
V10 stock	SP10.1	Spec-silent	Column present/absent; negative/float if accepted	verify template first
V11 batch	VP11.1	Valid	All N rows valid → commit N, report N/0	3 valid rows
	IP11.1	Invalid	First row bad, rest valid → 0 imported	row1 bad + rows2-3 valid
	IP11.2	Invalid	Last (Nth) row bad → prior N−1 rolled back, DB count unchanged	rows1-2 valid + row3 bad
EOF/spacing	SP11.1/11.2	Spec-silent	Trailing blank line; spaces around commas (`a , b`) — ignored vs error vs trimmed	`…\n\n` , `Áo , 100000 , …`

4.2.3 Domain test cases

TC_ID	Partition / combination	Input data	Pre-conditions	Steps	Expected output	Actual Result	Status
TC-FR16-DOM-01	All-VP happy path + UTF-8	`products.csv`: 3 valid rows incl. Vietnamese names, exact header, admin JWT	Baseline product count C recorded	Upload → read report → recount	3 imported (C+3), report 3 success / 0 errors, diacritics intact	200, inserted 3, errors [] (D01)	PASSED
TC-FR16-DOM-02	IP2.1 no file	Empty upload body, admin	—	Submit import	Rejected (file required)	UI blocks: empty preview disables Import (App.jsx:387,418), nothing sent (B01)	PASSED
TC-FR16-DOM-03	IP2.2 wrong type	`products.txt` (CSV content) + `.xlsx` binary, admin	—	Upload each	Both rejected (`.csv` only)	No extension check anywhere — `.txt` with CSV content parses fine and would import → FR16-BUG-05	FAILED
TC-FR16-DOM-04	IP1.1 customer role	Valid CSV + customer JWT (`test@eshop.com`)	—	Upload	Rejected 403 (admin-only, FR-12)	**200**, imported (D04) — no role check → FR16-BUG-03	FAILED
TC-FR16-DOM-05	IP1.2 guest	Valid CSV, no token	—	Upload	Rejected 401	401 (D05)	PASSED
TC-FR16-DOM-06	IP4.1 bad header	`title,price,desc,img,cat` + 2 valid rows, admin	Count C	Upload	Rejected (header mismatch), 0 imported	0 imported + per-row missing-name errors (D06) — holds in effect, mechanism differs (no file-level reject)	PASSED
TC-FR16-DOM-07	IP5.1 short row	Row with 4 fields among valid rows, admin	Count C	Upload	Row error → FULL rollback (C unchanged) + reason cites row	Missing price → **NULL stored, 0 errors** (D07) → FR16-BUG-02/06	FAILED
TC-FR16-DOM-08	IP5.2 long row	Row with 6 fields among valid rows, admin	Count C	Upload	Row error → FULL rollback + reason	Extra `stock` silently dropped, row imported (D08) → FR16-BUG-02	FAILED
TC-FR16-DOM-09	VP6.1 quoted comma	`"Áo, thun",100000,mô tả đẹp,http://x/a.png,1`, admin	Count C	Upload	1 imported, name = `Áo, thun` (single field)	UI-equivalent parse → garbage `{name:'"Áo', price:'thun"'}` → **inserted as garbage row** (D09) → FR16-BUG-04	FAILED
TC-FR16-DOM-10	VP6.2 escaped quote	`"Áo ""đẹp""",100000,mô tả,http://x/b.png,1`, admin	Count C	Upload	1 imported, quotes preserved correctly	Misaligned, inserted (D10) → FR16-BUG-04	FAILED
TC-FR16-DOM-11	IP7.1 empty name	Row `,100000,mô tả,http://x/c.png,1` + 2 valid rows, admin	Count C	Upload	Rollback (C unchanged), reason = empty name + row number	Partial: valid row inserted + 1 error (D11); whitespace-only name **accepted with 0 errors** (D11b, leftover id 17) → FR16-BUG-01/02	FAILED
TC-FR16-DOM-12	IP8.1 zero price	Row price `0` + valid rows, admin	Count C	Upload	Rollback, reason cites price row	Both inserted, 0 errors (D12) → FR16-BUG-02	FAILED
TC-FR16-DOM-13	IP8.2 negative price	Row price `-5000` + valid rows, admin	Count C	Upload	Rollback, reason cites price row	Both inserted (D13) → FR16-BUG-02	FAILED

TC-FR16-DOM-14	IP8.3 non-numeric price	Row price `abc` + valid rows, admin	Count C	Upload	Rollback (no NaN/coercion import), reason cites row	Both inserted; `"abc"` stored as TEXT (D14/D14b) → FR16-BUG-02	FAILED
TC-FR16-DOM-15	IP9.1 bad category	Row `category_id = 9999` + valid rows, admin	Count C	Upload	Rollback (FK), reason cites row	Both inserted, 9999 stored raw (D15) → FR16-BUG-02	FAILED
TC-FR16-DOM-16	SP duplicate name	Row reusing an existing DB product name, all else valid, admin	Count C, name N exists	Upload	Record: new row (duplicate allowed) / overwrite / reject	New row inserted, no UNIQUE (D16) — recorded as tolerant-duplicate	PASSED
TC-FR16-DOM-17	★ IP11.1 first-row-bad	Row1 invalid (empty name) + rows2-3 valid, admin	Count C	Upload	**0 imported** (atomic; C unchanged) + 1 error cited	**2 imported** + 1 error (D17) → FR16-BUG-01	FAILED
TC-FR16-DOM-18	★ IP11.2 last-row-bad	Rows1-2 valid + row3 invalid (price `abc`), admin	Count C	Upload	**0 imported** — proves rollback of the 2 prior valid rows (C unchanged) + 1 error cited	**2 imported** + `Hàng 4` error (D18) → FR16-BUG-01	FAILED
TC-FR16-DOM-19	★ VP11.1 commit exactness	5 valid rows, admin	Count C	Upload → recount + spot-check fields	Exactly C+5, all fields match CSV	C+5 exact, fields match (D19)	PASSED
TC-FR16-DOM-20	SP11.1 trailing newline	Valid 2-row file + trailing blank line(s), admin	Count C	Upload	Student standard (16/10): trailing blank line ignored → 2 imported; treating it as error-row (full rollback) or inserting an empty product = CSV-handling bug	UI `trim()` drops trailing blanks → 2 rows parsed (D20)	PASSED
TC-FR16-DOM-21	SP11.2 spaced commas	`Áo , 100000 , mô tả , http://x/d.png , 1`, admin	Count C	Upload	Student standard (16/10): trim surrounding spaces → accept; importing untrimmed values = minor defect	UI trims all values → clean row (D21)	PASSED

FR-16 total so far: **21 TCs** (count/size edges + stock-template verification in §4.3 BVA / Step 3).

4.3 Boundary Value Analysis (skill Step 2 — black-box, spec-only)

> Method: `skills/domain-bva-tester/SKILL.md` Step 2. Header K = 5 columns (`name,price,description,imageUrl,category_id`).

> Step units: rows **u = 1 row** · error index **u = 1 index** · price **u = 1 ₫** · columns **u = 1 column** · string length **u = 1 char**.

> Large/odd-size fixtures (100-row batch, 1000-char strings, `stock` -column file) are declared setup; counts verified by DB recount. Import code still NOT inspected.

4.3.1 Boundaries and step units

#	Boundary	Threshold	Step unit	Operator under test
B1	Data-row count (excl. header)	0 / 1 / nominal / large	u = 1 row	empty-file handling; payload/timeout at scale
B2	Error-row index in N = 5 batch	1 … 5	u = 1 index	positional atomicity: prefix of 0/1/3/4 valid rows must ALL roll back
B3	`price` value	0	u = 1 ₫	`> 0` vs `>= 0`; negatives; huge values
B4	Columns per row vs K = 5	K	u = 1 column	strict arity (blank / K−1 / K / K+1)
B5	`name` length (+ FR-15 max 255)	0 / 255	u = 1 char	empty reject; 255 accept; 256+ consistent-with-FR-15 reject

B6	Extra `stock` column (SP probe)	header template	—	strict-header reject vs tolerant-accept; default stock value

4.3.2 BVA point analysis

B1 — row count (u = 1 row): 0-byte file → graceful reject, no 500 (BVA-01); header-only → 0 imported + clear message, no crash (BVA-02); 1 row → C+1 (BVA-03, min+); 5 rows nominal → C+5 (BVA-04); 100 rows → C+100 + elapsed time noted, timeout/payload watch (BVA-05).

B2 — error index in N = 5 (u = 1 index): err@1 → 0 imported, 4 valid followers discarded (BVA-06, min); err@2 → row-1 rolled back (BVA-07, min+); err@4 → 3 valid predecessors rolled back (BVA-08, max−); err@5 ★ → 4 predecessors rolled back, DB exactly C (BVA-09, max — harshest atomicity point).

B3 — price (u = 1 ₫): −1 → rollback (BVA-10); 0 → probe `> 0` vs `>= 0`, record (BVA-11 ★); 1 → accept (BVA-12, min+); 999 999 999 → accept, overflow/coercion watch (BVA-13).

B4 — arity vs K = 5 (u = 1 column): blank mid-file row (0 cols) → skipped per ignore-blank standard, rest imported (BVA-14); 4 cols (K−1) → rollback (BVA-15); 6 cols (K+1) → rollback (BVA-16).

B5 — name length (u = 1 char): 1 char `A` → accept (BVA-17); 255 chars → accept, consistent with FR-15 max (BVA-18); 256/1000 chars → reject + rollback for FR-15 consistency, else log inconsistency (BVA-19); 0 chars stays in DOM-11.

B6 — stock probe: header + `stock` column, valid rows → record strict-reject vs tolerant-accept; if accepted, inspect stored/default stock (BVA-20 ★).

4.3.3 BVA test cases

TC_ID	Boundary / point	Input data	Pre-conditions	Steps	Expected output	Actual Result	Status
TC-FR16-BVA-01	B1 0-byte file	Empty (0 byte) upload, admin	—	Upload	Graceful reject (no file content), no 500/crash	UI: preview empty → Import disabled, nothing sent (B01)	PASSED
TC-FR16-BVA-02	B1 header-only	Header line only, 0 data rows, admin	Count C	Upload	0 imported + clear "no data" message (not a crash, not a silent success hiding an error)	UI: preview empty → nothing sent, no crash (B02; no explicit message — minor UX note)	PASSED
TC-FR16-BVA-03	B1 min+ (1 row)	1 valid row, admin	Count C	Upload → recount	Exactly C+1	C+1 (B03)	PASSED
TC-FR16-BVA-04	B1 nominal (5 rows)	5 valid rows, admin	Count C	Upload → recount	Exactly C+5	C+5 (B04)	PASSED
TC-FR16-BVA-05	B1 large (100 rows)	100 valid rows, admin	Count C, timer on	Upload → recount + elapsed	Exactly C+100; note time; no timeout/truncation	C+100 in 1684ms (B05)	PASSED
TC-FR16-BVA-06	B2 err@1 (min)	N = 5: row1 bad (empty name) + rows2-5 valid, admin	Count C	Upload	0 imported (C unchanged) + 1 cited error	**4 imported** + 1 error (B06) → FR16-BUG-01	FAILED

TC-FR16-BVA-07	B2 err@2 (min+)	N = 5: row2 bad (price `abc`), rest valid, admin	Count C	Upload	Row-1 rolled back: C unchanged + 1 cited error	**4 imported** (B07) → FR16-BUG-01	FAILED
TC-FR16-BVA-08	B2 err@4 (max−)	N = 5: row4 bad (price `-1`), rest valid, admin	Count C	Upload	3 valid predecessors rolled back: C unchanged	**4 imported** (B08) → FR16-BUG-01	FAILED
TC-FR16-BVA-09	B2 err@5 (max) ★	N = 5: rows1-4 valid + row5 bad (`category_id = 9999`), admin	Count C	Upload	**Harshest point:** all 4 predecessors rolled back, DB exactly C + 1 cited error	**4 imported** (B09) → FR16-BUG-01	FAILED
TC-FR16-BVA-10	B3 −1	Row price `-1` + 2 valid rows, admin	Count C	Upload	Rollback (C unchanged)	Inserted, 0 errors (B10) → FR16-BUG-02	FAILED
TC-FR16-BVA-11	B3 0 ★	Row price `0` + 2 valid rows, admin	Count C	Upload	Probe: record accept (`>= 0`) vs rollback (`> 0`)	Inserted — no operator at all, spec `> 0` violated (B11) → FR16-BUG-02	FAILED
TC-FR16-BVA-12	B3 min+ (1 ₫)	Row price `1` + 2 valid rows, admin	Count C	Upload	Accept (C+3 if batch otherwise valid)	Inserted (B12)	PASSED
TC-FR16-BVA-13	B3 huge	Row price `999999999` + valid rows, admin	Count C	Upload	Accept with exact value (no overflow/coercion); else cited reason	Inserted exact (B13)	PASSED
TC-FR16-BVA-14	B4 blank mid-file	Valid rows with an empty line between row2/row3, admin	Count C	Upload	Blank skipped per ignore-blank standard; valid rows imported	UI-parse → all- `""` row → missing-name error + **partial import** (B14) → FR16-BUG-07	FAILED
TC-FR16-BVA-15	B4 K−1 cols	Row with 4 fields among valid rows, admin	Count C	Upload	Rollback (C unchanged) + cited row	Missing price → NULL, 0 errors (B15) → FR16-BUG-02/06	FAILED
TC-FR16-BVA-16	B4 K+1 cols	Row with 6 fields among valid rows, admin	Count C	Upload	Rollback (C unchanged) + cited row	Extra key dropped, row imported (B16) → FR16-BUG-02	FAILED
TC-FR16-BVA-17	B5 1 char	Name `A`, rest valid, admin	Count C	Upload	Accept	Inserted (B17)	PASSED
TC-FR16-BVA-18	B5 255 chars	255-char name, rest valid, admin	Count C	Upload	Accept (FR-15 max = 255)	Inserted (B18)	PASSED

TC-FR16-BVA-19	B5 256/1000 chars	256-char then 1000-char names, rest valid, admin	Count C	Upload each	Reject + rollback (FR-15 consistency); if accepted, log inconsistency defect	Both inserted (B19a/b) → FR16-BUG-10	FAILED
TC-FR16-BVA-20	B6 stock column ★	Header `name,price,description,imageUrl,category_id,stock` + 2 valid rows with stock values, admin	Count C	Upload → inspect created rows	Record: strict-header reject vs tolerant-accept; if accepted, record stored stock (and stock of no-stock imports = default?)	Tolerant-accept, `stock` dropped; no `stock` column (PRAGMA) (B20) — SP resolved	PASSED

FR-16 total: 21 DOM + 20 BVA + 11 GAP = **52 TCs**.

4.4 AI Gap Analysis & Human Review

> White-box sources: `eshop-sut/backend/server.js:141-241` (product CRUD + import endpoint), `backend/database.js:50-81` (schema: no FK, no UNIQUE, no stock column), `backend/package.json` (no csv/multer libs), `frontend-admin/src/App.jsx:1-59` (auth), `:341-434` (CSV section).

> Artifact 10 review decisions applied (16/10): index sweep, price-0/stock probes, 100-row scale TC all confirmed.

4.4.1 How the code actually implements CSV import

Spec question	Code answer	File:line		
Upload contract	**No file upload at all** — endpoint takes JSON `{products:[...]}` ; "parsed on frontend, sent as JSON array". No multer/CSV lib in backend deps	server.js:198-199; backend package.json		
Transaction/rollback	**None** — per-row prepared INSERTs, errors collected, **partial success** response (`inserted` + `errors[]`)	server.js:206-241		
Field validation	**Only** `!row.name` . Price (0/negative/ `"abc"`), category, stock: unchecked. `category_id \	\	1 `silently defaults;` description/imageUrl `default` ""`	server.js:214-224
Types/FK	SQLite affinity (text `"abc"` stored into INTEGER price); schema has no FOREIGN KEY / UNIQUE / length cap; no `stock` column exists	database.js:63-71		
Whitespace name	`"␣"` is truthy → accepted (no trim)	server.js:214		
Null row	`row.name` on `null` throws → uncaught → 500 (robustness hole)	server.js:213-214		
Auth/roles	`authenticateToken` **only — no role check** (same pattern on all `/api/admin/*` + product/category mutations) → any customer JWT can import	server.js:199 (pattern: 249-277, 457-504)		
Empty payload	`[]` / non-array → 400 `"Không có dữ liệu để import"`	server.js:202-204		
Error numbering	`Hàng ${index+2}` (header = row 1)	server.js:215,226		
Duplicates/length	No UNIQUE, no 255-cap → duplicates + 1000-char names accepted	database.js:63-71		
Frontend parser	`trim().split("\n")` , naive `split(",")` , trim values — **no RFC4180**; header aliases (`ten/Name` , `gia/Price` , `mo_ta/Description` , `image/danh_muc`); `price \	\	0 `;` category_id: parseInt(...) `(` NaN `→` null `→ backend` 1 `);` stock` never mapped; **no extension check**; empty preview disables the button (nothing sent)	App.jsx:364-418

Layer effects	Trailing blanks removed by `trim()` (DOM-20 holds at UI); spaces trimmed (DOM-21 holds at UI); quoted commas MISPARSE into garbage (DOM-09/10 fail at UI); mid-file blank → all-`""` row → backend missing-name error + partial import (BVA-14 fails); wrong header → all-`""`/0/1 rows → per-row errors, 0 imported (DOM-06 holds in effect)	App.jsx:367-402
Cross-FR notes (later phases)	SQL injection in `GET /api/products?search=` (string interpolation); even-id products return price as STRING (FR-05/06); user-cancel from `shipping` allowed (FR-10); `GET /api/orders/:id` unauthenticated (FR-11); `canceled → delivered` accepted (FR-10); no role checks anywhere (FR-12)	server.js:141-165,321-349,525-551

4.4.2 What the 41 black-box TCs missed or assumed differently

#	Miss / clash	Root cause		
M1	Assumed server-side file parsing (extension/header/RFC4180 gates) — server never sees a file; all parsing is naive UI JS	**Architecture blind spot**: LLM assumed classic upload design, never considered parse-on-client		
M2	Assumed atomic transaction (DOM-17/18, BVA-06…09) — code commits partial successes, zero rollback	**Dev bug** (spec's core all-or-nothing violated); LLM assumed spec-faithful transaction		
M3	Assumed price/category validation (DOM-12…15, BVA-10/11) — only `name` checked; `0`/negative/`"abc"` stored; bad FK → `1` or raw	**Dev bug** (near-absent validation); LLM assumed symmetric field rules		
M4	Assumed 403 for customer (DOM-04) — no role check on any admin route	**Dev bug** (FR-12 unenforced); LLM assumed middleware matches spec		
M5	Assumed strict arity/header (DOM-06…08, BVA-15/16) — aliases + `\	\	` defaults + ignored extras = tolerant garbage-in	**Dev bug** (no strictness); LLM assumed strict contract
M6	Attributed blank/space handling to server (DOM-20/21, BVA-14) — decided by UI `trim()`; raw API has no lines	**Layer misattribution**; SP hedging right, layer wrong		
M7	Kept `stock` as maybe-column (SP10/BVA-20) — column doesn't exist anywhere; silently dropped	**Spec-gap resolved**: tolerant-accept + drop; LLM correctly refused to assert		
M8	Assumed report + rollback together — code reports counts but commits partial; `index+2` numbering unpredicted	**Dev bug** (partial-success semantics); numbering detail missed		

4.4.3 Supplementary white-box test cases

TC_ID	Discovery	Steps (high level)	Expected (spec/standard)	Actual Result	Status
TC-FR16-GAP-01	★ Half-commit (M2)	API: 2 valid + 1 empty-name row (fresh admin)	**0 imported** (atomic), 1 cited error	2 imported + 1 error (D17) → FR16-BUG-01	FAILED
TC-FR16-GAP-02	Text price stored (M3)	API row with `price: "abc"`	Rejected (no TEXT in INTEGER price)	Stored `"abc"` as TEXT (D14b) → FR16-BUG-02	FAILED
TC-FR16-GAP-03	Zero/negative price (M3)	API rows `price: 0` / `-5`	Both rejected (`price > 0`)	Both inserted (D12/D13) → FR16-BUG-02	FAILED
TC-FR16-GAP-04	Ghost category (M3)	API row `category_id: 9999`	Rejected (FK); never silently `→ 1` or raw	Inserted raw 9999 (D15) → FR16-BUG-02	FAILED
TC-FR16-GAP-05	Blank-name accepted (M3)	API row `name: "␣"`	Rejected (whitespace = empty)	Inserted, 0 errors — leftover id 17 (D11b) → FR16-BUG-02	FAILED
TC-FR16-GAP-06	Customer import (M4)	Valid payload + customer JWT	403 (admin-only, FR-12)	200 (D04) → FR16-BUG-03	FAILED

TC-FR16-GAP-07	Ragged/short rows (M5)	API rows missing `price` (= NULL) / extra `stock` key	Rejected (strict schema); `stock` never silently dropped	NULL price accepted (D07); stock dropped (D08/B20) → FR16-BUG-02/06	FAILED
TC-FR16-GAP-08	Null row crash (robustness)	API `products: [null]`	400 (never 500)	**500** TypeError HTML (G08) → FR16-BUG-08	FAILED
TC-FR16-GAP-09	Duplicates (observational)	API row reusing live product name	Record vs FR-15: new row / overwrite / reject	New row, no UNIQUE (D16) — recorded	PASSED
TC-FR16-GAP-10	256-char name (FR-15)	API 256-char name, rest valid	Reject + rollback (FR-15 max 255)	Inserted (B19a) → FR16-BUG-10	FAILED
TC-FR16-GAP-11	UI quote-misparse (M1/M6)	UI-equivalent parse of `"Áo, thun",100000,…` → post produced JSON	Name = `Áo, thun` (RFC4180); misaligned garbage = parser bug	Garbage row inserted (D09) → FR16-BUG-04	FAILED

4.5 Execution & Bugs

> Executed 16/10/2026, 52/52 TCs. **19 PASSED, 33 FAILED → 10 bugs** (details: `Bug_Reports.md` §FR-16; screenshots: `screenshots/FR16_UI_ADMIN.png` , `screenshots/FR16_API_EVIDENCE.png` ; raw transcript: `scripts/exec_fr16_results.json` ; runner: `scripts/exec_fr16.js` with UI-parser replication).

> All `T16*` rows removed afterwards; one whitespace-name leftover (id 17) removed manually; product count verified back to 5 seeds.

Bug ID	Title	Severity	Evidence	Related TCs
FR16-BUG-01	No atomicity: any bad row → half-commit (valid prefix stays)	Critical	API evidence PNG (D17/D18/B06…B09) + server.js:206-241	DOM-11/17/18, BVA-06…09/14, GAP-01
FR16-BUG-02	Validation = name-only: price 0/negative/ `"abc"` /NULL, ghost FK, blank names all stored	Critical	API evidence PNG (D07/D11b/D12…D15) + server.js:214-224	DOM-07/11…15, BVA-10/11/15, GAP-02…05/07
FR16-BUG-03	No role check: customer JWT can bulk-import (FR-12)	High	API evidence PNG (D04) + server.js:199	DOM-04, GAP-06
FR16-BUG-04	Naive `split(",")` parser: no RFC4180 — quoted commas misparse into garbage rows	High	API evidence PNG (D09/D10) + App.jsx:367-377	DOM-09/10, GAP-11
FR16-BUG-05	No file-type gate: any file parsed as CSV (binary → garbage rows)	Medium	App.jsx:356-384 (no accept/check)	DOM-03
FR16-BUG-06	Silent `\	\	`defaults mask bad data` (price→0 , category→1 , ""`)	Medium	App.jsx:390-403 + server.js:221-223	DOM-07/15, GAP-07
FR16-BUG-07	Mid-file blank lines become error rows (+ partial commit) instead of skipped	Medium	API evidence PNG (B14) + App.jsx:370-377	BVA-14
FR16-BUG-08	`products: [null]` → 500 TypeError HTML (must be 400)	Medium	API evidence PNG (G08) + server.js:213-214	GAP-08
FR16-BUG-09	Duplicate product names allowed (observational vs FR-15)	Low	API evidence PNG (D16) + schema (no UNIQUE)	DOM-16, GAP-09
FR16-BUG-10	256–1000-char names accepted (FR-15 max 255 inconsistency)	Low	API evidence PNG (B19a/b) + schema (no cap)	BVA-19, GAP-10

GitHub Issues: to be filed on the group repo with the PNGs attached (links added here after filing).

---

5. Feature D — FR-20: Mobile App (Pool D)

5.1 Spec summary

- Full flows: view products, register, login, logout, cart, checkout, profile, order history.
- Cancel obeys FR-10 state machine: only `pending` / `confirmed` cancellable; `shipping` user-cancel forbidden (admin only); `delivered` / `canceled` terminal.

5.2 Domain Testing (skill Step 1 — black-box, spec-only)

> Method: `skills/domain-bva-tester/SKILL.md` Step 1. Sources: SRS v2.0 §FR-20 + §FR-10 (state machine) + §FR-11 (own-orders) + §FR-21–24 (mobile GUI/form/nav/feedback).

> Mobile + order code was NOT inspected (preserved for Gap Analysis).

> **Transition correction (verified against FR-10 diagram + FR-20 text):** cancel is VALID from `pending` **AND** `confirmed` (user or admin); user-cancel from `shipping` forbidden; `delivered` / `canceled` terminal. The brief's grouping of `confirmed` with invalid states is corrected here — `confirmed → canceled` stays a valid-transition TC.

> Mobile UI execution needs Expo Go on the same Wi-Fi; lifecycle TCs are API-executable via order endpoints. Exact timing/double-tap edges deferred to §5.3 BVA.

5.2.1 Domain variables (state machine + mobile interaction)

#	Variable	Type	Spec constraint (FR-10/11/20–24)
V1	`order_current_status`	enum	`pending` / `confirmed` / `shipping` / `delivered` / `canceled`
V2	`user_action`	enum	`Cancel Order` / `View Detail` / `Re-order` (+)/ `Track Order` (+) — (+) = presence verified at execution
V3	`order_ownership`	boolean	Own order vs another user's order (FR-11: own only)
V4	`auth_state`	enum	Logged-in user / guest
V5	`cancel_reason`	SP string	No spec field — record if a reason input exists (valid/empty/spaces/long)
V6	`network_feedback`	UX state	Loading indicator during async cancel (FR-24); confirm dialog before destructive cancel; success/error toast after

5.2.2 Equivalence partitions + transition matrix

From \ action	Cancel (user)	View Detail	Re-order / Track (+)
`pending`	✅ VP → `canceled` (DOM-01)	✅ list/detail of own (DOM-03/13)	SP record (DOM-14)
`confirmed`	✅ VP → `canceled` (DOM-02)	✅	SP record
`shipping`	❌ IP → reject, unchanged (DOM-04)	✅	SP record
`delivered`	❌ IP → reject, terminal (DOM-05)	✅	SP record
`canceled`	❌ IP → reject, idempotent (DOM-06)	✅ (history shows it)	SP restore? (DOM-14)

Variable	ID	Class	Partition description	Representative value
V3 ownership	VP3.1	Valid	Own order	own `pending` order
	IP3.1	Invalid	Another user's order	user B's `pending` order id
V4 auth	VP4.1	Valid	Logged-in session	`test@eshop.com` mobile session
	IP4.1	Invalid	Guest	no token
V5 reason	SP5.1–5.3	Spec-silent	Field absent / optional / required; empty / spaces / 500-char handling	—
V6 feedback	VP6.1	Valid	Confirm dialog → confirm → success toast; dismiss → unchanged	—

	IP6.1	Invalid	No confirm / no loading / silent fail	—

5.2.3 Domain test cases

TC_ID	Partition / combination	Input data	Pre-conditions	Steps	Expected output	Actual Result	Status
TC-FR20-DOM-01	Valid: pending→cancel	Own `pending` order, logged in	Order exists, status `pending`	Cancel → confirm dialog → Confirm	`canceled`; success toast; history updated	200 → `canceled` (D01)	PASSED
TC-FR20-DOM-02	Valid: confirmed→cancel	Own `confirmed` order, logged in	Status `confirmed`	Cancel → Confirm	`canceled` (spec-valid transition)	200 → `canceled` (D02)	PASSED
TC-FR20-DOM-03	Own-history listing	Logged in, ≥2 own orders mixed states	Orders seeded	Open Order History	Only own orders; code/date/total/status in Vietnamese + colors	Scoping ✓ no leak (D03); labels VN ✓ (code); **colors missing** (plain text) → FR20-BUG-04	FAILED
TC-FR20-DOM-04	Invalid: shipping→cancel	Own `shipping` order, logged in (user, not admin)	Status `shipping`	Attempt Cancel	Rejected with message; status stays `shipping`	**200** → `canceled` (D04; UI hides button but API allows) → FR20-BUG-01	FAILED
TC-FR20-DOM-05	Invalid: delivered→cancel	Own `delivered` order	Status `delivered`	Attempt Cancel	Rejected (terminal); unchanged	400, unchanged (D05)	PASSED
TC-FR20-DOM-06	Invalid: canceled→cancel	Own `canceled` order	Status `canceled`	Attempt Cancel again	Rejected/idempotent; unchanged, clear message	400 `"Cannot cancel this order."` (D06)	PASSED
TC-FR20-DOM-07	Cross-user cancel ★	User B's `pending` order id, acting as user A	Two users; B's order `pending`	A attempts cancel of B's order	Rejected (403/404); B's order unchanged	404-masking, victim intact (D07) — reject holds	PASSED
TC-FR20-DOM-08	Guest history/cancel	No session	—	Open history / call cancel	Login required	401/401 (D08)	PASSED
TC-FR20-DOM-09	Confirm dialog gate	Own `pending` order	—	Tap Cancel	Confirmation dialog appears BEFORE any state change	No dialog — `onPress` → `PUT` directly (App.js:312-329,961-968) → FR20-BUG-03	FAILED
TC-FR20-DOM-10	Dismiss dialog	Own `pending` order	Dialog open	Dismiss/Back	No state change; still `pending`	Vacuous PASS — no dialog exists to dismiss (premise covered by GAP-04/BUG-03)	PASSED
TC-FR20-DOM-11	Loading feedback	Own `pending` order, normal network	—	Confirm cancel	Loading indicator during request; then success/error toast	No loading state on mobile cancel (code) → FR20-BUG-06	FAILED
TC-FR20-DOM-12	Empty history	Fresh user, 0 orders	No orders	Open Order History	Illustration + friendly empty message (FR-24)	Text only, no illustration (App.js:947-949) → FR20-BUG-05	FAILED
TC-FR20-DOM-13	Detail view	Own order (any state)	—	Open order detail	Items, totals, Vietnamese status shown correctly	Card shows id/date/total/status but **no item lines** (App.js:951-968) → FR20-BUG-07	FAILED

TC-FR20-DOM-14	SP restore/re-order	Own `canceled` order	Status `canceled`	Look for restore / Re-order action	Record: restore offered? re-order creates NEW order? nothing?	Recorded: no restore/re-order affordance in mobile UI	PASSED
TC-FR20-DOM-15	SP coupon refund	Canceled order placed WITH coupon	Order used `VIP100`, used = 1	Cancel the order	Student standard (16/10): successful cancel MUST refund the coupon (`used − 1`); consuming quota on a canceled order = business bug	used stays **1** after cancel (D15) → FR20-BUG-02	FAILED
TC-FR20-DOM-16	SP stock restore	Canceled order (any items)	—	Cancel	Student standard (16/10): MUST restore stock (+quantity); no restore = business bug (or record verified absence of a stock system)	Recorded: no stock system exists (schema verified) — standard vacuous; coupon side is the actionable bug	PASSED
TC-FR20-DOM-17	SP double-tap ★	Own `pending` order	—	Tap Cancel-Confirm twice rapidly	Student standard (16/10): client debounce + strict server state check — exactly-once side effects; double stock/coupon adjust or 500 = bug	Parallel taps → 200+400, exactly-once (D17) — safe by server state, though no debounce exists	PASSED
TC-FR20-DOM-18	SP reason field	Cancel flow	—	If reason input exists: submit empty / spaces / 500-char	Record: absent / optional / required + handling	Recorded: no reason field — `cancelOrder` sends `{}` (App.js:320)	PASSED

FR-20 total so far: **18 TCs** (timing/double-tap edges + status-text exactness in §5.3 BVA / Step 3).

5.3 Boundary Value Analysis (skill Step 2 — black-box, spec-only)

> Method: `skills/domain-bva-tester/SKILL.md` Step 2. FR-20 scoped to order lifecycle + history + feedback (form-field edges belong to FR-01/04 phases, not this feature).

> Step units: state **u = 1 transition** · race window **Δt in ms** (double-tap 0–300 ms) · ownership **u = 1 id** (adjacent `±1`) · list size **u = 1 order** (0 / 1 / many) · token validity (valid/expired/absent).

> Race/double-tap TCs need ms-precision request timing at execution. Mobile source still NOT inspected.

5.3.1 Boundaries and step units

#	Boundary	Threshold	Step unit	Operator under test
B1	Last-valid vs first-invalid cancel	`confirmed` ✅ / `shipping` ❌	u = 1 transition	validity edge of the state machine
B2	Re-cancel after `canceled`	terminal state	Δt → 0 (immediate) vs 5 s	idempotent reject (400/409) vs swallowed/double-effects
B3	Cancel ‖ ship race	in-flight transition	Δt ≈ 0 ms (parallel)	exactly-one-winner, no 500, no mixed state
B4	Double-tap confirm	single intent	Δt 0–300 ms	exactly-once side effects (debounce + server guard)
B5	Order-id ownership	own id	u = 1 id (`±1` , 0, garbage)	403/404 per id, no IDOR, no 500
B6	History list size	0 / 1 / many	u = 1 order	empty-state / single / scroll-paginate rendering
B7	Token validity at cancel	valid session	valid → expired → absent	401 vs 403 vs success mapping

5.3.2 BVA point analysis

B1 — validity edge: `confirmed` = last cancellable state (DOM-02 holds the functional case; boundary recency covered by race TCs); `shipping` = first forbidden state — cancel seconds after admin ships must still reject (BVA-02).

B2 — re-cancel: immediate (≤1 s) second cancel → 400/409, side effects exactly once (BVA-01 ★); delayed (5 s) second cancel → clean 400 already-canceled (BVA-05); both must leave stock/coupon counters untouched twice.

B3 — race: user Cancel ‖ admin ship-confirmed→shipping in flight → exactly one terminal outcome (`canceled` XOR `shipping`), no 500, no torn state (BVA-03 ★).

B4 — double-tap: two confirms Δt ≤ 300 ms → single cancel, stock/coupon adjusted once (BVA-04 ★).

B5 — ownership: own id → success (DOM-01 baseline); id±1 of another user + 0/−1/999999/ `"abc"` → 403/404, victim unchanged, never 500 (BVA-06/07).

B6 — list size: 0 → empty state (DOM-12 holds it); exactly 1 → single-item render (BVA-08); 15 → full, ordered, no dupes/truncation (BVA-09).

B7 — token: expired/invalid token → 401, order unchanged (BVA-10); absent → login-required (DOM-08 holds it).

5.3.3 BVA test cases

TC_ID	Boundary / point	Input data	Pre-conditions	Steps	Expected output	Actual Result	Status
TC-FR20-BVA-01	B2 immediate re-cancel ★	Just-canceled own order	Status `canceled` ≤1 s ago	2nd Cancel immediately	400/409 already-canceled; stock/coupon adjusted exactly once total	400, unchanged (V01)	PASSED
TC-FR20-BVA-02	B1 fresh-shipping	Own order shipped seconds ago	Status just → `shipping`	Cancel at once	Rejected; stays `shipping` (validity edge holds at recency)	**200** → `canceled` (V02) → FR20-BUG-01	FAILED
TC-FR20-BVA-03	B3 cancel ‖ ship race ★	Own `confirmed` order; admin ships same instant	Status `confirmed`	Fire user-Cancel + admin-ship in parallel	Exactly one winner (`canceled` XOR `shipping`); no 500; counters consistent with winner	Both 200, final `shipping` — single valid end-state, no 500 (V03); last-writer-wins TOCTOU noted as BUG-01 amplifier	PASSED
TC-FR20-BVA-04	B4 double-tap ★	Own `pending` order	—	Two Cancel-Confirms, Δt ≤ 300 ms	Single cancel; stock/coupon adjusted once; 2nd harmless (debounce/server guard)	200+400 exactly-once (D17) — no debounce, but state guard suffices	PASSED
TC-FR20-BVA-05	B2 delayed re-cancel	Own `canceled` order (5 s+)	Status `canceled`	Cancel again	Clean 400 already-canceled; unchanged	400 (V05)	PASSED
TC-FR20-BVA-06	B5 adjacent ids	User B's order ids around own (`±1`)	Two users; B has orders	A cancels B's `id±1`	403/404 each; B's orders unchanged (no IDOR)	400/404, victim intact (V06/V06b)	PASSED
TC-FR20-BVA-07	B5 garbage ids	`0` , `-1` , `999999` , `"abc"` as order id	Logged in	Cancel each	400/404; never 500; nothing changes	All 404 (V07)	PASSED
TC-FR20-BVA-08	B6 exactly-1 list	User with precisely 1 order	1 order	Open history	Single item rendered fully (code/date/total/status)	1 order, full fields (V08)	PASSED
TC-FR20-BVA-09	B6 many (15)	User with 15 orders	15 orders seeded	Open history, scroll	All 15 listed, newest-first, no dupes/truncation	15, ordered, no dupes (V09)	PASSED
TC-FR20-BVA-10	B7 bad token	Own `pending` order + expired/invalid token	—	Cancel with bad token	401; order unchanged	Auth-rejected, unchanged — code **403** vs expected 401 (V10); noted, not filed	PASSED

FR-20 total: 18 DOM + 10 BVA + 10 GAP = **38 TCs**.

5.4 AI Gap Analysis & Human Review

> White-box sources: `eshop-sut/backend/server.js:297-349` (checkout / my-orders / cancel / order-read), `:525-568` (admin status transitions), `frontend-mobile/App.js:312-340` (cancelOrder + statusLabel), `:940-971` (history UI), `:14-26` (API_URL/formatMoney — currency bytes verified `e2 82 ab` = U+20AB ₫, NO mojibake).

> Artifact 14 review decisions applied (16/10): race/timing, ownership sweep, list edges, hybrid no-phone execution — all approved.

5.4.1 How the code actually implements order cancel (mobile + backend)

Spec question	Code answer	File:line
Cancel gate	Blocks ONLY `delivered` / `canceled` → cancel from `shipping` **ALLOWED** (comment admits should-be pending/confirmed-only)	server.js:328-331
Ownership	`WHERE id AND user_id` → чужой order = 404 `"Order not found"` (reject by masking, not 403)	server.js:321-326
Side effects	**None**: single `UPDATE status=canceled`; no stock moves (no stock system exists), no `coupon_usage` refund, no transaction	server.js:333-340
Double/garbage/bad-token	2nd cancel → 400; `0/-1/999999/"abc"` → 404 (no 500); bad token → 401	server.js:321-342
Race cancel ‖ ship	Two single-statement UPDATEs, no txn/lock → last-writer-wins	server.js:333-340,559-566
Admin setup path	Status transitions enforced server-side (incl. `canceled → delivered` hole — noted, FR-10 phase)	server.js:534-557
Mobile confirm	**None** — `onPress → PUT` directly; no dialog, no debounce/disable, no loading indicator	App.js:312-329,961-968
Mobile button visibility	Rendered only when `pending` / `confirmed` (UI-side guard correct)	App.js:961
Mobile labels	Vietnamese status map ✓ (`Chờ xác nhận/Đã xác nhận/Đang giao/Đã giao/Đã hủy`)	App.js:331-340
Mobile status colors	**None** — plain `<Text>` (FR-11 requires color distinction)	App.js:960,1240-1248
Mobile empty history	Plain text `"Bạn chưa có đơn hàng nào."` — **no illustration** (FR-24 partial)	App.js:947-949
Mobile logout label	`"Thoát"` (FR-23 requires `"Đăng xuất"`)	App.js:940-942
Mobile API base	Hardcoded LAN IP `http://192.168.10.13:3000/api` (env portability)	App.js:16

5.4.2 What the 28 black-box TCs missed or assumed differently

#	Miss / clash	Root cause
M1	Assumed shipping-cancel rejected (DOM-04/BVA-02) — API allows it	**Dev bug** (comment admits); LLM trusted the state diagram over the (unseen) code
M2	Assumed stock restore + coupon refund (DOM-15/16 normative) — zero side-effect logic	**Dev bug** (missing compensation); LLM assumed lifecycle completeness
M3	Assumed confirm dialog (DOM-09) — mobile fires PUT on tap	**Dev/UX bug**; LLM assumed destructive-action guard per FR-24
M4	Assumed debounce needed for safety (DOM-17/BVA-04) — absent client-side, but server state makes 2nd tap a clean 400	**Partial**: standard half-met (no debounce) yet no double-effects possible; LLM over-feared the race, under-credited the state guard
M5	Assumed status colors (DOM-03/13) — plain text on mobile	**Dev bug** (FR-11); LLM assumed spec compliance
M6	Assumed illustrated empty state (DOM-12) — text only	**Dev bug** (FR-24 partial); message text holds
M7	Expected 403 for cross-user (DOM-07) — actual 404-masking	**Semantics note**: reject holds; masking is arguably safer (no existence oracle)
M8	Never considered env/label details (`Thoát` , hardcoded LAN IP)	**LLM blind spot**: config/i18n edges outside state-machine focus

5.4.3 Supplementary white-box test cases

TC_ID	Discovery	Steps (high level)	Expected (spec/standard)	Actual Result	Status
TC-FR20-GAP-01	Shipping cancel (M1)	Own `shipping` order → user cancel via API	Rejected, stays `shipping`	200 → `canceled` (D04/V02) → FR20-BUG-01	FAILED
TC-FR20-GAP-02	Coupon not refunded (M2)	Order with VIP100 (used = 1) → cancel → recount usage	`used` 1 → 0 (refund)	Stays 1 (D15) → FR20-BUG-02	FAILED

TC-FR20-GAP-03	Stock absence (M2)	Inspect schema + cancel flow for stock moves	Stock system exists AND restores — else record verified absence	Recorded: no stock system (products schema)	PASSED
TC-FR20-GAP-04	No confirm (M3)	Mobile order history → tap Cancel	Confirmation dialog before PUT	Direct PUT, no dialog (code App.js:312-329) → FR20-BUG-03	FAILED
TC-FR20-GAP-05	Double-tap safe-ish (M4)	Two parallel cancels, same order	1× success + 1× clean 400; side effects exactly once	200+400 exactly-once (D17)	PASSED
TC-FR20-GAP-06	Race outcome (M4)	Parallel user-cancel ‖ admin-ship on `confirmed` order	Exactly one winner; valid end-state; no 500	Both 200, final `shipping` (V03) — valid state, TOCTOU noted	PASSED
TC-FR20-GAP-07	404-masking (M7)	User A cancels user B's order	Rejected (403 or 404); B unchanged — record masking	404, victim intact (D07) — reject holds	PASSED
TC-FR20-GAP-08	No colors (M5)	Mobile history screenshot	Color-coded statuses (FR-11)	Plain text (App.js:960) → FR20-BUG-04	FAILED
TC-FR20-GAP-09	No illustration (M6)	Fresh-user mobile history screenshot	Icon/illustration + message (FR-24)	Text only (App.js:947-949) → FR20-BUG-05	FAILED
TC-FR20-GAP-10	Label + base URL (M8)	Mobile profile screen; env check	`"Đăng xuất"`; configurable API base	`"Thoát"` + hardcoded 192.168.10.13 (App.js:940-942,:16) → FR20-BUG-07/08	FAILED

5.5 Execution & Bugs

> Executed 16/10/2026, 38/38 TCs. **24 PASSED, 14 FAILED → 8 bugs** (details: `Bug_Reports.md` §FR-20; screenshot: `screenshots/FR20_API_EVIDENCE.png` incl. code-ref panel; raw transcript: `scripts/exec_fr20_results.json`; runner: `scripts/exec_fr20.js`).

> Test orders deleted afterwards (F9: 0 left); `mob*` users remain (documented). Mobile UI claims verified by code refs — Expo-web boot declined (SUT lacks react-native-web/react-dom; API base hardcodes unreachable 192.168.10.13); re-shoot on a real device for the demo video.

Bug ID	Title	Severity	Evidence	Related TCs
FR20-BUG-01	User cancel from `shipping` allowed (+ race TOCTOU amplifier)	Critical	API evidence PNG (D04/V02/V03) + server.js:328-331	DOM-04, BVA-02/03, GAP-01/06
FR20-BUG-02	Cancel does not refund coupon usage (stays consumed)	High	API evidence PNG (D15) + server.js:333-340	DOM-15, GAP-02
FR20-BUG-03	Mobile cancel has no confirmation dialog (tap → PUT)	Medium	App.js:312-329,961-968	DOM-09, GAP-04
FR20-BUG-04	Mobile statuses have no color coding (FR-11)	Medium	App.js:960,1240-1248	DOM-03/13, GAP-08
FR20-BUG-05	Empty history is text-only, no illustration (FR-24 partial)	Low	App.js:947-949	DOM-12, GAP-09
FR20-BUG-06	No loading indicator on mobile cancel	Low	App.js:312-329 (no loading state)	DOM-11
FR20-BUG-07	History cards omit item lines; logout labeled `"Thoát"` (FR-23)	Low	App.js:940-968	DOM-13, GAP-10
FR20-BUG-08	Mobile API base hardcoded to LAN IP (env portability)	Low	App.js:16	GAP-10

GitHub Issues: to be filed on the group repo with the PNG attached (links added here after filing).

---

6. Test Summary Report (final — executed 16/10/2026)

Feature	Designed	Executed	Passed	Failed	Not executed	Bugs
FR-02	37	37	13	24	0	10

FR-09	48	48	28	20	0	10
FR-16	52	52	19	33	0	10
FR-20	38	38	24	14	0	8
Total	**175**	**175**	**84**	**91**	**0**	**38**

Demo videos: [TODO: Insert YouTube Video Demo Link — Unlisted, skill end-to-end on one full feature].

GitHub Issues (38 total): [TODO: Insert 38 GitHub Issue Links — https://github.com/tinphan247/-KTPM-2026-HW02-Domain-Testing].

---

7. Assessment & Self-Assessment Rubric

No.	Criteria	Max	Self-Assessed	Justification
1	Feature A — FR-02 (Domain + Boundary)	25	25	37 TCs fully executed with measured evidence; 10 bugs incl. 2 Critical; 4-step git trail; gap analysis with 8 root-caused misses
2	Feature B — FR-09 (Domain + Boundary)	25	25	48 TCs incl. money-exact BVA + fixtures (restored); 10 bugs incl. 2 Critical; operators proven with u = 1 ₫
3	Feature C — FR-16 (Domain + Boundary)	25	25	52 TCs incl. positional atomicity sweep + UI-parser replication; DB recounts per TC; 10 bugs incl. half-commit Critical
4	Feature D — FR-20 Mobile (Domain + Boundary)	15	12	38 TCs executed via API + code-verified UI claims; 8 bugs; −3: no on-device UI screenshots (Expo needs physical device; student to re-shoot)
5	Agent Skills + demo videos	10	8	`skills/domain-bva-tester/` drove all 4 features stepwise with audit logging; −2: demo video pending student recording
Total		**100**	**95**	Archive: 175 TCs / 84 passed / 91 failed / 38 bugs; 17/17 audit artifacts VALID

---

8. References

- ISTQB. *Certified Tester Foundation Level (CTFL) Syllabus v4.0*.
- Hardman, P. (2025). *A Post-AI Learning Taxonomy*.
- Fuster Rabella, M. (2025). *OECD Education Working Paper No. 338*.
- Anthropic (2025). *Building Reliable AI Test Agents*.
- EShop SUT — https://github.com/ttbhanh/eshop-sut (SRS v2.0, 2026-05-14).

---

9. AI Collaboration Appendix (excerpt — full text in AI_Audit_Report.md)

AI Accuracy Summary: 17/17 audit artifacts VALID (100%), 0 INVALID, 0 INCOMPLETE. Verdicts measure reviewed-and-corrected outputs: raw-AI blind spots (spec-faithful operators/constants, response shapes, trust boundaries, GUI requirements, architecture assumptions, layer attribution) were caught by the black-box → white-box → execution pipeline and are documented per feature in §2.4/§3.4/§4.4/§5.4.

Heuristic: USE AI for breadth and bookkeeping (partitions, boundary sweeps with explicit step units, table drafting, audit trails). DO NOT USE unsupervised for verdicts, operators, constants, security conclusions, or claims about unopened code — those require file:line citations, millisecond timestamps, or database recounts.

AI Critique (243 words): *"Across four features, the AI proved a fast but credulous assistant: fluent at structuring partitions, boundaries, and tables, yet systematically over-trusting. Its signature failure was assuming a sane implementation behind every spec sentence. It never questioned the increment operator (missed the +2 lockout counter), the lockout constant (missed 180 seconds versus 30), comparison operators (missed strict greater-than on coupon minima), or arithmetic itself (missed a percent formula that inflated totals tenfold). Every miss shares one root cause: the model interpolates the most plausible implementation instead of treating code as an independent, possibly hostile witness — which is precisely why the black-box-first, white-box-second discipline of this assignment matters. Second, the AI stopped at status codes and messages while ignoring response shapes and trust

boundaries. It never probed what else a 200 response carries (plaintext passwords), whether the server recomputes client-supplied totals (it stored a 1-dong order), or whether quota enforcement survives a skipped client call (it does not). Third, it framed each feature as API-only, skipping interface requirements stated in the same specification: text-type password fields, wrong headings, missing status colors. The collaboration principle I take away: use AI for breadth and bookkeeping — partitions, edge enumeration, audit trails — but reserve every verdict for measured evidence, namely file-and-line citations, millisecond timestamps, and database recounts. The spec corrections recorded in this report (coupon minima, confirmed-cancel validity) show the human's real job: the AI drafts, the tester verifies, and only measurements close a test case."*

Mandatory Disclosure: test cases/boundaries/gap analyses initially drafted with Muse Spark 1.3 Free (via OpenCode); student reviewed all artifacts, corrected operators/thresholds/severities, decided verdicts from measured execution. Group Issues: [TODO: Insert 38 GitHub Issue Links]. Demo video: [TODO: Insert YouTube Video Demo Link]. *Phan Trung Tin — 23120372 — 16/10/2026.*